Sortes Engineering Retrospective

Product: Sortes by Resonant Atlas, a tarot reading web app (Next.js), live at https://sortes.resonantatlas.com **Repository:** github.com/Velu2k03/Sortes-Muse, local copy at ~/workspace/sortes/ **Period covered:** 2026-09-29 (concept) to 2026-11-08 (Phase I acceptance, CONDITIONAL GO, 90/100) **Author:** Muse (the main agent), compiled 2026-11-08 from the project record **Status of this document:** historical record. It describes what happened, what was decided, what failed, and what was left open. It does not change any of it.

How to read this document

Evidence is tagged by strength so nothing is overstated:

- **Verified live:** observed directly in a browser, a dashboard, a log, or a test run, with a time and a result.
- **File-recorded:** stated in a tracker, report, decision log, diagnosis, or commit message in the project record. The source file is named.
- **Parent session record:** verified in the live working session on 2026-11-08 and recorded in MEMORY.md line 158, where the goal files end before the event. Used only for events the files do not cover (the ledger fix being applied, the Google enablement, the checkout 401 resolution, the Phase I verdict).
- **Unresolved:** two or more sources disagree, or the evidence does not settle the point. These are flagged, not smoothed over.

Scores in this document are the scores the reports gave at the time. They are never re-inflated here. Where a headline score disagrees with its own area sum, both numbers are shown and the discrepancy is named.

No em dashes are used in this document, per the owner's standing rule.

1. The product and the starting point

1.1 Concept (2026-09-29, file-recorded)

Sortes is a personalized tarot reading PWA. The concept came from a Filipino friend's tarot business intake flow. The owner (Velu Murugan) defined the product identity early and it never changed:

- Brand: "Sortes by Resonant Atlas". The name "drvelu" never appears in Sortes. The root resonantatlas.com is untouched.
- Tagline: "Cast the lots. Read your story."
- Philosophy: reflection, not prediction.
- Pricing from the start: first reading free; credit packs First Light 5 Oracles $3.99, Constellation 12 Oracles $7.99 ("Most popular"), Celestial Treasury 30 Oracles $14.99. Flat 1 Oracle per reading or report. Credits never expire. No subscriptions.

- Stack: Next.js at ~/workspace/sortes/, repo github.com/Velu2k03/Sortes-Muse, hosted on Vercel, Supabase (Postgres + Auth), Lemon Squeezy (store 244487, Resonant Atlas, pay.resonantatlas.com), Resend for email, OpenRouter free models for AI generation.

1.2 How the work was organised (file-recorded)

The main agent does NOT code Sortes itself. All Sortes code was done in Antigravity using claude-opus-4-6-thinking. The main agent briefs, supervises, QCs, screenshots, and verifies only. The stated fallback: if Antigravity actually fails (quota, error, or stalled run), the main agent starts coding Sortes itself to finish the work. That fallback applies only on an actual failure, not while a run is still going. This division of labour matters for the retrospective because most code defects were found by independent review, not by the author of the code.

Standing hard gates from the start (2026-11-03, file-recorded):

- No production deploy, no production secret changes, no irreversible production database operations, no git push without explicit per-push approval.
- No price, monetisation, or Oracle-cost changes.
- No paid AI models.
- No production env, secrets, settings, or data changes without approval.
- No real purchases. No altering live customer balances.
- No invented testimonials, statistics, or customer proof.
- ub-mode on every code change.
- Verify every finding in current code before changing it. Do not claim fixed unless verified by build plus lint plus relevant test plus visual check where applicable.

1.3 The state before the transformation (2026-11-02 to 2026-11-04, file-recorded)

By early November the app existed and was live on a Vercel URL, but it had never been through a systematic audit. Known decisions from this period:

- Domain sortes.resonantatlas.com was the owner's decision, live 2026-11-03. The alternative tarot.resonantatlas.com was not used, never assigned, DNS does not resolve. It must not be re-added.
- Design references picked by the owner (2026-11-04): Stripe pricing, Linear, Vercel, shadcn/ui (site and GitHub), Apple Human Interface Guidelines. Rule: extract layout, spacing, responsive behaviour, visual hierarchy, and component patterns, do not blindly copy them; use actual browser previews, screenshots, and working examples before implementing designs.
- PixelCard was chosen by the owner by link and exact props. The broad direction to keep all React Bits and use them much more extensively was given twice by the owner.
- The pixel transition is ONLY on the daily card reveal (gold pixels back to face, then HoloCard tilt on hover). It is OFF reading reveals and charts.
- The Sortes no-chatbot boundary was set (2026-11-03, owner's words): "do not turn the whole Sortes experience into a chatbot; keep the beautiful visual tarot, astrology and reflection experience, even while adding personalization, follow-ups and guided explanations."
- React Bits rule (2026-11-03/04): "if no official React Bits component exists, find the closest official alternative, never hand-code a replacement first."

- Phase 4 gate was evaluated 2026-11-03 and NOT met: M4.1 premium keep-forever reports stayed unbuilt; the gate needs M2.2 retention proof (7-day revisit moving, follow-up reference rate above 80%), no such data exists; it unblocks after at least 7 days of real use after the Nov 4 deployment, then measure. The owner may override the gate explicitly; the agent does not override it alone.

2. The roast (2026-11-05): 52/100

2.1 What happened

Two independent roasts were run on the live site as a guest on desktop, no sign-in, no payment, no account, plus a code read at branch sortes-audit-remediation, HEAD fa02ea8. Mobile at 390px was not tested. Muse roast: 52/100. Argon roast: 51/100.

Per-area scores (Muse roast): First impression 58, UX/navigation 55, Conversion/pricing/paywall 38, Content 78, Product strategy 35, Engineering/security 42, Performance/accessibility 55, Trust 40.

2.2 The 18 problems (R1 to R18)

Five were P0:

- **R1, free reading promise breaks.** The button reads "Get Oracles" and opens the top-up modal, then flips on reload. Root cause stated as a render race: the paywall button renders first, the free state arrives late, if at all.
- **R2, free chart interpretation fails twice.** Toast "Failed to generate interpretation. Please try again." No diagnostic, no fallback.
- **R3, pricing not agreed.** Prices are client-rendered, absent from server HTML, and three attempts produced three answers.
- **R4, credits-migrate mints Oracles.** No cap, no one-time guard.
- **R5, demo checkout grants paid product free when Lemon Squeezy env vars are absent.**

The remaining thirteen: R6 identical sample readings (Star, Sun, Magician across five spreads); R7 currency confusion (Oracles, credits, dollars, USD never stated, tax never stated); R8 guest journal in localStorage only, no export, Clear journal risk; R9 76 animations, three runtimes, zero code-splitting; R10 push prompt promises reminders that do not exist; R11 no social proof; R12 reports sample only a skeleton; R13 deck card detail has no URL, dialog only; R14 the name Sortes never explained on the homepage; R15 guides with no author, date, or read time; R16 account page with two products wearing one label; R17 header and footer disagree with URLs; R18 hero stock moon, low contrast, empty space.

2.3 The roast's own errors (file-recorded, important)

The roast's first browser pass was unreliable, and this matters as a methodology lesson:

- It reported six pricing packs up to $199.99, spreads costing 2, 3, or 4 Oracles, and a duplicate FAQ question. All three were wrong. The code defines three packs and six spreads at 1 Oracle, and the FAQ had zero matches.

- Its reports claim (dollar prices, no sample) was withdrawn by a 07:32 UTC correction the same day after a direct re-check: reports are 1 Oracle and a layout sample exists. The overall score stayed 52.
- The roast's live pricing conflict (packs 5/20/50/100/200/500) was likewise withdrawn the same day: a direct re-check confirmed live values match the code.

Lesson recorded in the roast notes: treat delegated browser text as a lead, never as evidence. Verify every live claim against the code and by a direct re-check before quoting it.

3. The transformation (2026-11-05): 45 commits, 155 files

Started 23:07 Manila, 2026-11-05. Branch sortes-transformation-2026-11-05, baseline fa02ea8, tag pre-transformation-fa02ea8, HEAD at delivery 859bdb6. 45 commits, 155 files, +8,554 / -5,300 lines. Nothing pushed, merged, deployed, or changed in production.

- **Phase 1, Security, money, data safety (P0):** credits migrate route deleted; signup returns 409 for any existing email; checkout claim nonce bound; Lemon Squeezy webhook verified and atomic with refund revocation; demo checkout free grant removed; vitest added; CSP added; shared rate limiter.
- **Phase 2, Broken core functionality (P0):** one question-first AI flow; first free Quick Insight honoured server side; /daily truncation fixed and TextType deleted; shared AI client src/lib/ai.ts with retry and static chart fallback; input validation; dark Celestial Indigo default and contrast fixes.
- **Phase 3, Trust, UX, naming, safety (P1):** PushPrompt removed; CODE FIELD PREVIEW deleted and FAQ Q7 rewritten; /credits renamed to /oracles and /history to /journal with redirects; duplicate titles fixed; journal safety; account with equal Create / Sign in plus Export All Data and Delete Account; distinct sample per spread; apology copy removed by fixing causes; horoscope lucky colour and number removed; birth card Personality and Soul pair.
- **Phase 4, Design, navigation, charts, deck, performance, accessibility, SEO (P1-P2):** anchored header popovers; typable time and IANA timezone/DST charts plus Vedic diamond; deck Grid default with 78 static /deck/[slug] pages; sacred geometry spread diagrams; restrained homepage hero; dead animation components deleted; code splitting and lint 72 to 0; accessibility pass for header, deck, and spreads; SEO titles, sitemap, and canonical domain; HoloCard WebGL shader replaced by CSS gold rim light.
- **Phase 5, Build the moat (P2):** Pattern Mirror dashboard; saved birth profiles; clarifier card on follow-ups; Heirloom PDF export plus Markdown journal export; shareable 9:16 story cards.

Final verification at delivery: build passes, lint 0 problems (was 81 at baseline), tests 160/160 in 26 files (was 0), charts-check exit 0, local smoke 17 routes HTTP 200, sitemap 78 card URLs. Visual and mobile checks were NOT done. That gap is recorded here because it recurred: visual and mobile verification kept being deferred and kept being owed at every later checkpoint.

4. Release readiness review (2026-11-06): 58/100, NO-GO

An independent review of HEAD 859bdb6. Verdict: NO-GO for launch today, CONDITIONAL GO once five must-fix gates close. The live site was still the old build.

The review caught two transformation claims as false, which is the single most important verification lesson in this retrospective:

1. The shared limiter had NOT replaced six per-route maps. The claim was false at review time; six per-route new Map limiters still existed.
2. "160/160 tests" was true but misleading for payments, because zero tests executed the Postgres branch.

New findings N1 to N12:

- **N1:** silent JSON fallback when POSTGRES_URL/DATABASE_URL unset.
- **N2:** Supabase OTP length mismatch risk (8-digit enforcement versus Supabase default 6 digits). Later closed by evidence: Supabase OTP is 8 digits, 1 hour expiry, matches the code. No code fix needed.
- **N3:** rate-limit gaps (account/delete, account/export, /api/history POST, chart/transits, vedic-transits, ziwei-stacks, reports, auth/me, stats unrated).
- **N4:** account deletion needs only a session cookie; sessions are non-revocable 30-day JWTs.
- **N5:** balance not checked before AI generation.
- **N6:** guest free use is client-trusted.
- **N7:** follow-up lost-update race.
- **N8:** guest reports never migrated; guest free flags not carried over, so a second free after sign-in. Recorded as a known Phase 2 gap, funnel cost 1 Oracle per user. Not fixed in the files.
- **N9:** webhook has no outer error handling, no reconciliation, no alerting.
- **N10:** sessions coupled to the Supabase secret.
- **N11:** no indexes, no CHECK constraints, nonce table grows forever.
- **N12:** local fallback unsafe even for dev.

Per-area scores: Security 8, Payments 5, Balance 6, Postgres/SQL 4, Auth 5, AI 4, UI/UX 8, Desktop/mobile QA 7, SEO 8, Deployment 3. Sum 58.

The review's gates (older G1 to G5 numbering, do not mix with the Phase H G1 to G14 set): G1 Postgres proven plus fail-fast guard, G2 money paths on real Postgres, G3 sign-in verified live, G4 test-mode checkout end to end, G5 backup plus rollback in place. All must be green, no partial credit.

5. Phase 6 (2026-11-06): 80/100, CONDITIONAL NO-GO

Phase 6A hardening (9 commits) plus Phase 6B independent verification (3 commits) plus 1 principal follow-up commit. HEAD at report time 6381be2. Production untouched.

6A items: production fail-fast guard; claim endpoint deleted; versioned migration system 001 to 003; shared limiter replacing six per-route maps; balance before AI plus atomic follow-up spend; real-Postgres money-path suite plus JSONB double-encoding fix; delete re-authentication; horoscope hydration fix; 390px overflow fix; env and README docs; backup runbook; staging doc; webhook simulator; reconcile script; OTP and AI fallback tests.

6B items: independent verification; env audit (docs/ENVIRONMENT.md); staging env file; backup and restore scripts tested; RLS 004 prepared but NOT applied; verifier fixes in 4982d7c including stale balance, production auto-apply hole, fail-closed guard, delete both-present, migration 003.

Verification: lint 0, vitest 210/210 with both local Postgres URLs, build pass, webhook simulator PASS twice, 12 screenshots with 0px overflow, 0 console errors.

Bugs found during Phase 6 verification (each is a lesson in itself):

- **JSONB double-encoding:** `${JSON.stringify(x)}::jsonb` under postgres.js stores a JSON string, not an object. It broke when the driver changed to postgres.js on 2026-11-02. Fix: central `jsonbParam()` using `pg.json()` at all four write sites; migration 002 repairs already double-encoded rows.
- **Limiter claim false again:** six per-route maps still existed after the claim they were replaced. Fixed in 6A a20666f. This is the second time a "replaced" claim was false. The pattern is: a claim about removal or replacement must be verified by grep, not by reading the new code.
- **Lint claim wrong:** lint had 1 error (react-hooks/set-state-in-effect, horoscope page line 51). Fixed in d88cf5c.
- **Generate returned a stale pre-spend balance, off by 1.** Fix: re-fetch the user after spend, plus a regression test.
- **ensureSchema auto-applied pending migrations in production.** Fix: requires SORTES_MIGRATE_PRODUCTION=1 or a non-production env; production only verifies and names pending versions.
- **DB guard bypass:** the guard threw only on exact-match production; an unset or misspelled NODE_ENV bypassed it. Fix: throws unless NODE_ENV is development or test.
- **Account delete with both password and code was silently password-preferred; the code was never consumed.** Fix: now rejected, test added.
- **VM replacement wiped the system Postgres cluster, role, and databases while ~/workspace survived.** Re-created per docs/STAGING.md; test suites rebuild schema, no test data lost. This recurred multiple times in Phase 6, Phase 7, and the mission phases. Local Postgres is ephemeral across VM replacements. Any plan that depends on a local database must include a recreate step.

Per-area scores: Security 9, Payments 7, Balance 9, Postgres 9, Auth 8, AI 6, UI/UX 9, QA 9, SEO 8, Deployment 6. Sum 80.

Phase 6 gates (older numbering): G1 GREEN, G2 GREEN, G3 GREEN, G4 RED, G5 AMBER. G4 red because test-mode checkout needs a deployed preview. G5 amber because no production backup has run yet.

6. Phase 7 (2026-11-06 to 2026-11-07): 81/100, CONDITIONAL NO-GO

Branch pushed to origin at ad68ce7; origin main still 375c7a1. Preview Ready at https://sortes-muse-5ig64jpm6-velus-projects-27f81f38.vercel.app, commit ad68ce7. Live site still the old build 375c7a1.

E2E Tests 1 to 6 executed on Preview; Test 7 (mobile 390px) NOT DONE:

- Test 1, password sign-in: PASS. Code path delivers no code.
- Test 2, free Quick Insight: PASS on 2nd attempt.
- Test 3, paid 3-card reading plus follow-up: PASS on 2nd attempts, order lemonsqueezy:9965127, balance 0 to 5 to 4.
- Test 4, test checkout plus webhook: PASS after the Vercel Deployment Protection 401 fix.
- Test 5, duplicate plus refund: PASS.
- Test 6, account deletion: PASS.

Headline findings: AI first-attempt reliability 0/3; sign-in by email code delivers no code; no production backup exists.

6.1 AI reliability (the highest-impact user-facing failure after auth)

Phase 7 E2E baseline: 3 generations, old chain (Nemotron, Xing, router with flat 25 s timeouts). First-attempt success 0/3, retry success 3/3. Nemotron timed out 6/6 at 25 s. Xing4.0 returned OpenRouter 429 6/6. openrouter/free returned empty on first attempts and succeeded on retries. No Oracle was ever spent on a failure.

Two AI-chain fix passes followed. 7.FIX HEAD 8345b18 (Gemma 4 26B/31B plus Nemotron Lightning) failed live with 429s and empty responses. 7.FIX2 HEAD ad68ce7 (Nemotron Ultra plus Xing4.0 plus openrouter/free). Then 8A added a retry, then Phase D reordered the chain to openrouter/free first, Nemotron Ultra second with a 60 s timeout, Xing4.0 last. The Phase D measurement plan (6 generations, confirm if at least 3 of 6 succeed on pass 1 with median latency under 60 s and no success over 115 s) was still unrun at Phase I.

Other AI findings from the same period:

- Chart interpretation failed twice in re-test task 2 (about 2 minutes, then about 90 s). The fallback standard interpretation rendered and saved, balance stayed 10. Root cause narrowed at 15:00 on 2026-11-07: the same chain succeeded for a reading in the same run, so the chart failure was chart prompt or validation, not a provider outage or limit.
- Chart diagnosis 15:05: prompt and budget mismatch. The chart prompt is about 836 words (about 1,110 tokens), and the system prompt demands both 350 to 550 words and one section per key placement group, which is contradictory for a 43-aspect chart. A faithful answer of 700 to 1,000+ words fails the 300 to 600 validator ceiling or gets truncated by the 1200-token cap. Fix 1 in commit edc7b25: maxTokens 1200 to 2000, group placements into no more than four sections.
- An independent Nov 3 sweep found the router drew a content-safety classifier 2 of 3 times, and rejected requests (429/404/503) did NOT count against the OpenRouter daily counter (78 sent, 22 used).
- One transient model timeout in Phase I Vercel logs at 08:55:58, openrouter/free, 25 s timeout on /api/chart/interpret. Model calls succeeded shortly after at 08:56:23 and 08:57:37. A known free-model reliability caveat, not a blocker.

6.2 Other Phase 7 failures

- **Sign-in by email code delivers no code.** The Supabase template sends only a magic link, never a numeric code, in staging and production. The fix chosen was Option A, magic link, in Phase 8A A1.
- **Test checkout first failure:** Vercel Deployment Protection returned 401 to the webhook, balance stayed 0. Fix: Protection Bypass secret appended to webhook 149521 URL as ?x-vercel-protection-bypass=.
- **Header balance pill briefly shows 0 while /account loads; /account stuck on "Loading your account..." for 8+ seconds once.** Fix in Phase B P0-1: 10 s AbortController timeout, loadError flag with retry, skeleton pill that never renders 0 for unknown balance.
- **Vercel 300 s timeouts on /api/auth/me and /api/credits/transactions, 01:13 to 01:21 PST 2026-11-07.** This was the first visible symptom of the hang covered in section 8.

- **Reveal my reading slider does not respond to pointer drags in the automation browser; pressing End triggers reveal.** May be an automation artifact; a real-device finger test is still owed.
- **Horoscope hydration error #418, module-level new Date().** Fix in Phase 6 D2: date computed client-only after mount.
- **10px horizontal overflow at 390px on every page tested.** Fix in Phase 6 D3: header padding and gap, Top up hidden below sm, overflow-x clip backstop. A visual 390px screenshot was still owed at that time.
- **Spreads title "Past / Present / Future" still wraps.** The transformation claimed it fixed; the review found it not fixed. Cosmetic only.
- **Deck card name truncation on mobile:** "The High Priestess" renders as "The High Prie".

Per-area scores: Security 9, Payments 9, Balance 9, Postgres 9, Auth 7, AI 5, UI/UX 8, QA 9, SEO 8, Deployment 8. Sum 81. Movement from Phase 6: Payments +2, Deployment +2, Auth -1, AI -1, UI/UX -1.

Phase 7 gates (older numbering): G1 GREEN, G2 GREEN, G3 AMBER, G4 GREEN, G5 AMBER. G4 flipped RED to GREEN because checkout, webhook, duplicate, and refund were proven live on Preview. G3 flipped GREEN to AMBER because Phase 6 had recorded OTP 8 digits from a setting and treated sign-in as verified, but E2E proved the delivered email contains only a magic link, never a code. A setting is never behaviour. G5 stayed AMBER: no production dump.

7. Mission Phases A to G and Phase 8A (2026-11-07)

7.1 The mission order (2026-11-07 02:05, file-recorded)

The owner ordered the Autonomous Product Completion mission: turn Sortes into an excellent, trustworthy, complete product and launch it safely. Targets 100/100 per dimension, never inflated. This pass stops at Phase H gate review. No merge to main, no production deploy by the coordinator. The parent runs browser E2E and executes the production release.

Mission authorisation as recorded: merge and deploy to production are authorized ONCE all mandatory gates are GREEN. Production migrations, RLS changes, and env changes happen only after proving the exact change in staging, inspecting the SQL and its expected effects, and verifying backup plus rollback.

7.2 Phase A audit (read-only, HEAD ad68ce7)

Four parallel read-only workstreams: security, product, UX/mobile/accessibility, backup design. No file modified, no test suite executed, no live system touched.

- **Product audit:** 74 items (34 DONE, 21 PARTIAL, 16 MISSING, 3 FALSE-CLAIM).
- **Security audit:** 46 claims (30 VERIFIED, 5 PARTIAL, 6 STALE/FALSE, 5 NEEDS-LIVE-TEST), 17 risks.
- **UX audit:** 28 findings (P0 4, P1 13, P2 11), code arithmetic only, no browser.

Findings that shaped the rest of the mission:

- Deploy-before-migrations would brick the app (the deploy-order rule, see section 9.2).

- The webhook had no independent Lemon Squeezy order verification. `getOrder` had zero callers; the webhook checked only the `status` field inside the signed payload. The readiness review claim of API verification was false. HMAC authentication bounded the practical risk to a compromised webhook secret.
- Sessions were non-revocable: bare HS256 JWTs with `sub` plus `email` only, no `jti`, no version, no revocation list. Logout only clears the browser cookie; `set-password` does not rotate or invalidate anything. A stolen token stays valid for the full 30 days after password change and after logout.
- The header 0-flash root cause, dialogs lacking focus traps, the free-use claim race, and guest unlimited free AI throttled only per instance.
- Chart and report output was never validated server-side. Tarot had a lenient validator (word count 100-1200 and at least half the card names mentioned; no check for question, positions, spread facts, reflection question, next step, or the prompted 350-550 band). `chart/interpret` called `generateChat` with no validate function. The swap test was not implemented.
- The API returns the serving model and every client discards it; no reading shows "Written with [model]" or an AI-generated label. The only honest label sits on the failure-path chart fallback.
- Methodology page contradicts the code on Vedic timezones (FALSE-CLAIM): the page says longitude-only conversion with no DST; the code has used IANA with DST since Phase 4B. The Ziwei bullet is similarly stale.
- Privacy page promises on OpenRouter's behalf ("does not use it to identify you"), which is unverifiable; free-tier models may log prompts.
- Vedic yogas and Ashtakavarga do not exist in code (only the panchanga daily yoga). No 337-point Ashtakavarga checksum exists. The model is never told they are absent, so it can invent them.
- RLS was disabled on all 7 production tables; Supabase Advisor had 2 CRITICAL issues. With RLS off, anyone holding the public anon key could read emails, password hashes (users), and code hashes (auth_codes) through the PostgREST endpoint. No app code ever calls PostgREST; all data access goes through src/lib/db.ts with the postgres role, which bypasses RLS as owner/superuser. The exposure was real and the fix was zero-policy RLS (deny by default).
- Plaintext sign-in codes were logged by src/lib/email.ts:14 and returned as `devCode` in API responses, gated only on NODE_ENV. And `.env.example` ships SORTES_LOCAL_DEV_CODE=1 UNCOMMENTED, so copying it enables code return on any host where NODE_ENV is unset or not production.
- `spendUserCredits` accepted a negative amount, which would add credits.
- `history` PATCH/DELETE were unrated and history POST body size unbounded.
- No alerting, no log drain, no scheduled reconciliation. A failing webhook or a Resend outage is invisible until a customer complains.
- CSP keeps `unsafe-inline` for script and style, documented as required by Next.js inline bootstrap scripts; nonce-based CSP via middleware is a post-launch item.
- `auth/me` GET is deliberately unrated and called on every page load; the 300 s timeouts on it are unexplained.
- At HEAD ad68ce7, src/lib/ai.ts logs only `no-api-key`, `model-failed`, `chain-timeout`, and `all-models-failed`. There is no `model-succeeded` event and no second pass, no `maxPasses`, no `overallTimeoutMs`.

7.3 Phase B security and financial integrity (HEAD 58dbe19)

RLS 005 written and tested locally; webhook getOrder verification; session pwdVer plus migration 006; atomic free-use claims; spend guard; devCode gating; login IP bucket; reconcile URL preference; POST /api/credits/balance deleted; history limits; focus trap; header 0-flash fix.

Adversarial review: CONDITIONAL GO, with exactly one must-fix-before-push item (fix the charts-check assertion at scripts/charts-check.mjs:526, stale since commit 1c0bd9f). Independent numbers: `npm run lint` exit 0, `npx tsc --noEmit` exit 0, full vitest first run 274 passed 0 failed (second run 1 flaky timing failure in ai.test.ts, passed 3 of 3 alone), RLS test 6/6, `npm run build` exit 0, `node scripts/charts-check.mjs` exit 1 (the stale assertion).

Follow-up batch landed HEAD 8eaa54d, 288/288 tests. A stuck auth-button bug was fixed in 2563b69: one shared busy flag for four independent actions with every await unbounded; fixed with per-action flags and every auth fetch bounded at 10 s, plus 5 TDD regression tests. The exact stall origin was unproven from code alone.

Phase B also surfaced these gaps in its own work (honest self-review):

- `getOrder` has NO timeout, so a hung Lemon Squeezy API hangs the webhook until the Vercel function limit kills it. If LEMONSQUEEZY_API_KEY is missing, getOrder always returns null, so every paid order returns 500 forever and is never fulfilled, with no alert; the only backstop is the manual reconcile script.
- `req.text()`, the signature check, and JSON.parse sit OUTSIDE the try/catch, and the catch returns 500 for non-transient errors too (for example "User not found during fulfillment"), which Lemon Squeezy retries forever.
- The fulfilment duplicate check is a leading-wildcard LIKE on `pack_type` (%lemonsqueezy:%), which cannot use the index and is unanchored, so order 123 would match a row for order 1234. Nearly unreachable today because Lemon Squeezy ids increase monotonically, but the pattern is wrong.
- The login IP bucket takes the FIRST x-forwarded-for entry, which is client-controlled, so an attacker can rotate a forged first entry and get a fresh bucket per attempt. The limiter is also in-memory per instance, not shared.
- RLS safety depends entirely on the app connecting as the postgres/owner role. If the connection role ever changes to a non-owner role, the app would silently see 0 rows. There is no startup assertion for this.
- The follow-up route's free use is NOT atomically claimed: two concurrent first follow-ups on the same reading both see length 0 and both go free. Bounded at 1 extra free follow-up per reading.
- `appendFollowUpWithSpend` takes an unguarded `cost` parameter and `addUserCredits` has no guard at all (zero callers).
- The 64 KB per-reading history cap is applied AFTER `req.json()` parses the whole body, so it does not bound parse-time memory.

7.4 Phase C backup design (2026-11-07)

Age encryption (X25519 plus XChaCha20-Poly1305 AEAD). Public key only on runners; private key only in Secure Vault plus the owner's own copy. `gpg` is the fallback; `openssl enc` was rejected (unauthenticated CBC by default). Supabase CLI `db dump` was rejected as a primary: its default dump has no data and no custom roles, output is plain SQL with no compression, and it needs CLI plus Docker plus an access token.

Primary runner: runtime-managed Muse cron on the VM, daily 03:00 Asia/Manila. Primary offsite: Google Drive folder "Sortes Backups", one encrypted .age blob per day, 14-day retention. Fallback runner: GitHub Actions scheduled workflow, cron `7 19 * * *` (03:07 Manila), artifacts retained 14 days. RPO 24 h, RTO under 1 h, cost $0/month.

Open questions left in the design: Q1 whether runtime cron workers run on the same VM with the same $HOME, PATH, and ~/.config; Q2 who receives the GitHub failure email; Q3 actual free space in the owner's Google account; Q4 whether pg_dump via the session pooler includes auth.users rows; Q5 Supabase CLI v3 remote-default behaviour. Q4 was never answered by the verification log, which counts only the 7 app tables.

7.5 Phase D AI reliability (commit 272e9cb)

Chain reordered to openrouter/free first, Nemotron Ultra second with a 60 s timeout, Xing4.0 last. Budgets unchanged: 80 s per pass, 170 s overall. Xing4.0 kept, no new model added, no max_tokens or temperature change. E2E measurement still owed at Phase I.

7.6 Phase E product completion (13 commits, HEAD 086ab9c)

Validators plus swap test, AI and model labeling, methodology rewrite, astrology depth, yogas plus Ashtakavarga golden test (0/84 mismatches, checksum 337), daily evening return, follow-up relabel, onboarding samples, privacy fixes, spread facts. Verification 350/350 tests.

7.7 Phase F design and usability (HEAD 596b554)

44px touch targets, opaque disabled states, contrast floor, SlideCommit width, table affordances, drawer and keyboard gaps, PurchaseConfirmer baseline, Orb single loop, share fonts, HoloCard props removed, Sortes token defaults, PixelCard deleted (688 lines, zero imports).

One correction in the same pass: the first report wrongly claimed charts pills were 44px; nine missed buttons were fixed and pinned by charts-check 5b assertions. The coordinator also fixed its own SyntaxError (duplicate headerSrc declaration). Claiming a visual fix without measuring it is the same failure mode as the limiter claim in Phase 6.

P1-3 header 390px tightness was left open.

7.8 Phase G full verification (HEAD 7a2cc24, follow-up 2a1bedf)

36 new tests, F11 startup assertion, plans file hidden_files/phaseG-e2e-plans.md. Adversarial review CONDITIONAL GO at 7a2cc24. Follow-up HEAD 2a1bedf, 396/396 tests: refund-before-fulfilment marker, F11 allowlist, reports/generate 503 test, F1 session-email hardening, missing order id 400, migration 002 skip test.

The refund-before-fulfilment hole is worth recording: a redelivered order_created after a refund could grant unrevoked credits. Fixed with a pending-refund marker, a zero-value refund transaction row with null user_id, and a fulfillOrder check for any :refund row before granting.

Other Phase G corrections: F11 changed from a denylist to an allowlist (postgres, sortes_test, postgres., throw for anything else); a follow-up test flake (1-in-76) fixed by seeding Math.random to 0.999.

7.9 Phase 8A (ordered 2026-11-07 01:59, E2E completed 08:08)

- A1 commit 1c0bd9f: magic-link sign-in copy (tab "Email code" to "Email link", sent step, Supabase verifyOtp branch removed, FAQ Q7 rewritten).
- A2 commit e6a5fb5: AI success logging plus one bounded server-side retry, maxPasses 2, 170000 ms overall cap, 80 s per-pass budget, per-model timeout 25 s unchanged, chain order unchanged at that point.

Preview tested: deployment 5YJvTQm2Lwa5JALzhttvfTauPzeP, commit e6a5fb5, Ready 2026-11-07 02:53:43 Manila. Verdict CONDITIONAL NO-GO, 85/100 headline (84 by area sum).

E2E results:

- Magic-link screens pass, but clicking the link lands signed out because the redirect goes to the branch-alias root, not /auth/callback; a manual direct-host callback worked.
- Quick Insights 3/3 first attempt on Nemotron Ultra (7,024 ms, 11,720 ms, 10,879 ms).
- Paid 3-card reading failed after about 300 s with zero sortes-ai lines plus a simultaneous /api/history 300 s timeout.
- Purchase order 9967615 paid $3.99 but credited to a newly created account for the Link email futureai2077@gmail.com.

Fix round completed about 08:27, HEAD c7f2ba4, verified by the parent, pushed about 08:37:

1. Checkout attribution by signed-in user id, commit 32b506f.
2. Magic-link redirect is a Supabase Redirect URLs allow-list gap, not code, commit 37b6c0f (tests plus spec only).
3. Database-hang mitigation, 10 s server-side statement_timeout, commit c7f2ba4.

Score stays 85 until the fixes are proven live.

Per-area scores: Security 9, Payments 8, Balance 10, Postgres 9, Auth 7, AI 7, UI/UX 9, QA 9, SEO 8, Deployment 8. Sum 84; headline 85. The headline exceeds its own area sum by 1. The same off-by-one appears in the gate pack (headline 86, sum 85). The revised readiness doc avoids the error by showing the arithmetic in full. This is recorded here so future reports show their arithmetic.

8. The database hang (2026-11-07 to 2026-11-08): four diagnosis rounds

8.1 Symptoms

On staging (Preview), with code at b19ec8a and the transaction-mode pooler (port 6543), the app stalled within minutes: two independent fresh-instance stalls at 00:33 and 00:35, one cancel unanswered for about 106 s. The hang hit sign-in, history, credits, and the paid reading route. The pre-switch failure rate was about 8.5% of invocations (Vercel Observability, 06:52 entry), with failures in bursts (21 timeouts 09:00 to 09:46, none 09:46 to 10:14). Phase 7 logs also showed several 300 s Vercel timeouts on /api/auth/me and /api/credits/transactions

around 09:13 to 09:21 UTC on 2026-11-07. A session check stayed wedged for 7 minutes at 15:14 on 2026-11-07: the magic-link send worked, the click landed on /account?auth=ok, and the session check then failed six consecutive times.

8.2 Root cause: unproven

The trigger is unknown. The leading suspects are Supavisor issues #1205 and #1239 (transaction-mode pipelining, "hold backend until Sync"), but they were not reproduced. Session mode avoids the multiplexing path, which is plausible, but the mechanism is inferred, not proven. This is stated plainly here because the project record states it plainly: the hang was fixed by a configuration change whose mechanism was not proven.

8.3 The four diagnosis rounds

Round 1 (commit c7f2ba4): 10 s server-side statement_timeout. It did NOT stop the hangs live. Root cause later proven: statement_timeout never reaches the server through a transaction-mode pooler. PgBouncer only applies tracked startup parameters, and statement_timeout is not tracked. A local PgBouncer 1.22 transaction pooler with the app's exact factory proved it: `SHOW statement_timeout` returned 0 (direct Postgres: 10s) and `pg_sleep(15)` ran the full 15 s with no 57014. Pool acquisition was also unbounded: a measured SELECT 1 waited the full 20.0 s with max:1 held.

Round 2 (commit dafc067, then d1c698a): client-side 12 s deadline on every DB call (30 s on the schema check), plus server ALTER DATABASE statement_timeout 10 s. Then the finding that the 12 s deadline is a bare Promise.race: it abandons, never cancels, the lease stays held, queue_timeout defaults to 0, and idle_timeout and max_lifetime skip leased connections. Fix in d1c698a: AbortController plus Query.signal, pool.cancel, queue_timeout 12, migration exemption for idle_in_transaction_session_timeout. Caveat recorded in the recommendation file: CancelRequest routing through the session pooler was not verified; earlier research covered transaction mode only. A re-test on d1c698a still failed at sign-in at 22:29, and the pool-unwedging fix did NOT un-wedge the session check in that run.

Round 3 (commit 1c690fa): a 22:33 snapshot found exactly one app server session, pid 177428, state ACTIVE, wait_event ClientRead, xact_age 00:03:01, query SELECT 1 FROM information_schema.tables. Mechanism: the backend received the Parse of the migration-ledger check and waits for the rest, most likely Sync. Postgres deliberately defers query-cancel while reading a protocol message. Fix: postgres.js 4.0.0 to 4.1.0, cancel_timeout 5, plus transaction_timeout 60 s on staging at 23:29. Note: this bumped postgres.js, which made the gate pack claim "No new dependencies (package.json / package-lock.json diff is empty)" stale. A re-test on 1c690fa still failed at sign-in at 00:07 on 2026-11-08.

Round 4 (commit b19ec8a): the migration-ledger check had no cancellation. readAppliedVersions sends two ledger queries as raw pg template calls with no withDbTimeout and no signal; ensureSchema wraps runMigrations in a bare Promise.race withTimeout that cancels nothing. So a ClientRead stall on the ledger check means no cancel is ever issued, cancel_timeout never arms, and the lease is held until the server kills it or the instance is recycled. Also, the underlying error was swallowed by Promise.race by construction, so Vercel logs could only ever show the friendly timeout. Fix in b19ec8a: readAppliedVersions through withDbTimeout with the label migration-ledger, underlying-error logging, and a per-instance id DB_INSTANCE_ID. Re-test 4 on b19ec8a still failed at sign-in at 00:38, but the logging worked: start-to-error about 12 to 13 s on the sql() path, not the 30 s migration path; a retry on a new instance 2c9dc51c also stalled on getUserById in 12 s; a

transactions query cancel went unanswered for about 106 s and settled only at 00:35:03 with CONNECTION_DESTROYED / CANCEL_UNANSWERED when a new invocation thawed the frozen instance; a history query cancel was answered promptly with 57014. Conclusion recorded at the time: the stall recurs on fresh instances, on a lone SELECT, with no concurrency needed; it points at the connection or pooler itself.

8.4 The session-mode decision (CONDITIONAL YES)

All four commits were kept as defense-in-depth, because the root cause is unproven and the passing staging run exercised code plus session mode together.

The recommendation (file-recorded): switch Production POSTGRES_URL to session mode (5432), bundled into the Phase H release deployment, not as a separate change. Production had never shown the hang, so a standalone switch bought nothing.

Evidence for the switch (staging only): after the switch at 01:22 (deployment DdGn35m8F, 5432), 3/3 magic-link sign-ins, chart interpretation on first attempt, a mismatched-email purchase credited correctly (balance 10 to 15), zero `db-timeout` lines, no CANCEL_UNANSWERED, no CONNECTION_DESTROYED, no 57014. Same code before and after, so the pooler mode is the separating change.

Honest limits, all stated in the same file:

- Small sample, short window: about 15 minutes, one user, roughly 15 to 20 DB-touching requests. At 8.5% independent failures, the chance of zero failures in 15 requests is about 26%. Bursty failures make a quiet 15 minutes even more likely.
- No concurrency test. Session mode dedicates one backend connection per client connection, so the failure mode is pool exhaustion under many concurrent Vercel instances, and one browser user cannot reveal it.
- Confounders: the staging DB password was reset and a fresh deployment was created in the same step.
- Evidence is secondhand: the author read the decision log's account of browser tasks and did not independently view the Vercel logs or sign-in runs.
- Production had no hang evidence either way: production deployment 375c7a1 had 0 function invocations in 12 h.
- The switch deliberately departs from Supabase docs, which recommend transaction mode for serverless and edge functions. The docs confirmed session mode is port 5432, supports prepared statements, and queues clients for up to a minute when full, but did not confirm default pool size, the exact full-pool error text, whether statement_timeout passes through the session pooler, or how session clients count against max_connections.
- The passing staging configuration also had DB-level timeouts in place (statement_timeout 10 s, idle_in_transaction_session_timeout 60 s, transaction_timeout 60 s). A production switch without them is a different configuration from the one tested.
- Credential problem: the production password lives masked inside the Vercel Secret POSTGRES_URL and cannot be revealed; staging required a password reset (Route 2). Route 1 (preferred) is to obtain the password from Secure Vault; Route 2 (reset) would break the live production deployment until redeploy and invalidates every other holder (backup.env, GitHub Actions secret, local scripts).

- Conditions before switching: G1 backup GREEN first; a read-only dashboard check of pool size and max_connections; a staging concurrency soak; the credential route decided; the production Postgres version confirmed before attempting transaction_timeout; written abort criteria; the owner's per-run approval for each env change.
- Code search found no feature that assumes transaction mode (no advisory locks, LISTEN/NOTIFY, temp tables, cursors WITH HOLD, SET SESSION). `prepare: false` (db.ts:373) is harmless in session mode; `max: 1` (db.ts:374) is even more important there; `validatePostgresUrl` (db.ts:57 to 85) accepts both ports but its comment and error text still say transaction mode "is what this app requires", which is stale wording.

8.5 SMTP, the parallel saga (2026-11-07)

The built-in Supabase sender caps at 2 emails per hour per project and only delivers to team addresses: a production blocker. Fix: custom SMTP via Resend. The rate limit was raised 2 to 25 at 14:11:27 and 25 to 100 at 14:17:35. Then the SMTP password proved wrong: 9 attempts 14:28 to 14:49 failed with 500 and "535 Authentication credentials invalid", zero mail.send entries. The stored connector key was proven valid for the Resend API, so the value in Supabase was a different wrong value entered by the owner at 14:16. Fix: the password was replaced at 15:05 by the owner entering the correct Resend API key himself, and sending was proven after.

9. Phase H gate pack, revised readiness, and production day (2026-11-07 to 2026-11-08)

9.1 Phase H gate evidence pack (HEAD 2a1bedf, 52 local commits ahead of origin branch e6a5fb5, NOT pushed, push hold in force)

Score 86/100 headline, 85 by area sum, CONDITIONAL NO-GO. Per-area: Security 9, Payments 9, Balance 10, Postgres 9, Auth 8, AI 6, UI/UX 9, QA 9, SEO 8, Deployment 8. Sum 85. Movement from 8A sum: Payments +1, Auth +1, AI -1.

Gates G1 to G14 at pack time: GREEN 5, AMBER 5, RED 3 (the table splits G3 and G7 into code and applied/live rows, so the count is ambiguous if split rows are counted separately; the pack states GREEN 5, AMBER 5, RED 3):

- G1 Production backup completed plus restore verified plus daily schedule tested: RED. Implemented locally but the first production run never happened. Blocked on the owner supplying production POSTGRES_URL, the age keypair ceremony, Drive folder creation, daily cron approval, and Actions secret/variable setup.
- G2 Migrations tested on staging: AMBER. Tested on local Postgres only. Blocked on the staging DB password reset.
- G3 RLS reviewed and tested: GREEN code / AMBER applied. Reviewed and tested locally. Not applied to staging or production.
- G4 No critical/high security issues: GREEN. Adversarial review CONDITIONAL GO, zero Critical, zero High. Five Mediums found, four fixed, one (170 s vs 120 s) is a release condition.

- G5 Credit/payment integrity verified: GREEN local. Money paths on real Postgres, webhook simulator 4/4 plus refund-first PASS. Live payment E2E still owed.
- G6 Auth verified: AMBER. Code plus unit tests green. Magic-link callback E2E still owed. Phase 8A Preview E2E partial.
- G7 AI failures do not charge: GREEN code / AMBER live. All four AI routes have a 503 no-spend test. Live first-attempt reliability unproven. Phase D measurement unrun.
- G8 Preview E2E passes: RED. No Preview deployment of 2a1bedf exists under the push hold. Plans file written and ready.
- G9 Build plus lint pass: GREEN. tsc 0, lint 0, build 0, charts-check 0 at final HEAD.
- G10 No important console errors: AMBER. No browser run against this HEAD exists.
- G11 Mobile tests pass: RED. No real-device test exists. P1-3 header tightness at 390px still open by design. P1-4 overflow CI still open.
- G12 Rollback documented plus executable: AMBER. Documented per migration. Never executed against production. Depends on G1.
- G13 Production env vars verified: AMBER. Last verified Nov 6. AUTH_SECRET, RESEND_API_KEY and EMAIL_FROM, CRON_SECRET additions each need approval.
- G14 Production changes have clear reviewed impact: GREEN. PRODUCTION-CHANGE-PLAN.md documents each change with effect, risk, and rollback.

Accepted risks recorded in Gate Pack section 10, not closed by Phase I: fabricated-report save via POST /api/reports; session-expiry guest degradation (1 Oracle per expiry); guest double-free Quick Insight (1 Oracle per user); history id collision; refund branch without getOrder symmetry; the 170 s vs 120 s watch item; the Ashtakavarga grid verified against a transcribed published grid, not fetched against an external Astro Clock AI source; two cross-city four-hour assertions near-trivia; pending-refund marker rows have null user_id and are not removed by deleteUser; the plans file lives in goal hidden_files, not the repo, so it is not versioned with release candidate commits.

9.2 Revised readiness (2026-11-08 07:30): 90/100, CONDITIONAL NO-GO

Branch HEAD d54a639, production deployment 375c7a1. The live site was DOWN until redeploy because the owner reset the production DB password himself at 02:51, before the parent do-not-reset message landed. Production POSTGRES_URL was updated at 02:58 to session mode port 5432 with the new password. Production SQL was applied at 03:09: 001, 002, 003, 006, 004 RLS, 005 RLS, plus three timeout ALTERs. The production backup was done and restore verified at 07:07 (GitHub Actions run 42423673087, 45 s, SUCCESS, artifact 321,479 bytes). Verdict CONDITIONAL NO-GO, 90/100.

Per-area: Security 9, Payments 9, Balance 10, Postgres 10, Auth 9, AI 8, UI/UX 9, QA 9, SEO 8, Deployment 9. Sum 90. Changes from the recomputed 88: Postgres +1 because migrations plus RLS were applied to production and verified via backup restore; Deployment +1 because the production backup was done and verified.

Gates at revised readiness: GREEN 7 (G1, G3, G4, G5, G8, G9, G14), AMBER 6 (G2, G6, G7, G10, G12, G13), RED 1 (G11). Flips since the pack: G1 RED to GREEN (backup run plus verified restore); G8 RED to GREEN (session-mode re-test on Preview DdGn35m8F passed all four parts); G3 AMBER applied to GREEN (RLS 004 and 005 applied to production 03:09 and verified via backup restore). G2 stayed AMBER because the staging test itself was still owed and the migration ledger was not updated, even though production application

is stronger than a staging test for the release. G6 stayed AMBER because production sign-in was unproven until deploy. G13 stayed AMBER because AUTH_SECRET, CRON_SECRET, and RESEND_API_KEY were generated but not yet set in Vercel.

The revised readiness doc found six contradictions or stale claims in the record (see section 14 of this retrospective). It also recorded the deploy-order rule that had been missing from every earlier plan: migrations 001 to 003 must be applied to production BEFORE merge and deploy, with pg_dump before and after. Deploying first would take every database-backed route down. The plan's procedure was the migrate CLI with SORTES_MIGRATE_PRODUCTION=1, which updates the ledger. What actually happened on production day was the SQL Editor route, which does not update the ledger. That single deviation caused Bug 1 (section 10.1).

9.3 Production day, 2026-11-08: sequence of events (parent session record, verified live)

- 02:46: the owner chose Route 2 (password reset) and approved the daily 03:00 backup; cron sortes-daily-backup set 02:46.
- 02:47: production CONFIRMED from the owner's Supabase screenshot: "VELU1231's Project" IS production, ref adgputwbdtdmgkiswtnz, Status Healthy, compute size NANO, GitHub Velu2k03/Sortes-Muse, no migrations, no backups.
- 02:51: the owner ALREADY reset the production password; the live site was DOWN until redeploy; he ordered "fix all the issues in Supabase, like rls and more". The new password was used transiently only for backup.env (mode 600) and the Vercel update, never stored in memory or elsewhere.
- 02:58: Vercel Production POSTGRES_URL set to session mode port 5432 with the new password; Preview untouched; no deploy triggered.
- 03:00: backup cron ran and FAILED; the age keypair was still missing.
- 03:09: SQL fixes done, all six files applied to production ONLY, each "Success. No rows returned", in order (001 baseline, 002 indexes, 003 drop checkout_nonces, 006 session_version, 004 RLS, 005 RLS) plus three timeout ALTERs (statement_timeout 10s, idle_in_transaction_session_timeout 60s, transaction_timeout 60s). Staging never opened. Migration ledger NOT updated.
- 02:41 (same morning): Google Drive folder "Sortes Backups" created in the owner's Drive root.
- 07:02: the owner granted the gh `workflow` scope via device flow (first code DB45-950D expired at 15 min; second code F930-D34A worked).
- 07:07: G1 BACKUP GREEN. GitHub Actions run 42423673087, 45 s, SUCCESS. Artifact sortes-backup-42423673087 (321,479 bytes, .dump.age, age-encrypted, X25519). Downloaded and decrypted to .dump (320,939 bytes, PostgreSQL custom dump v1.16, PG 17.6). Restore verified in isolated local DB sortes_restore_verify: all 7 tables present; users 1 (velu2k03@gmail.com, 128 credits, pwd_ver 1), transactions 8, readings 1, auth_codes 0, reports 0, free_interpretations 0, free_readings 0; RLS enabled on ALL 7 tables. Four restore errors, all Supabase-platform only (transaction_timeout is PG17-only; supabase_vault extension not installed locally). No app data affected. pg_restore 17.11 was installed from the PGDG apt repo because PG16 pg_restore cannot read a v1.16 dump. The /tmp plaintext copy was deleted.
- 07:15: GitHub account verified. The gh CLI is authenticated as Velu2k03, and after the owner granted the "user" scope (device code B999-3568, authorized 07:15), `gh api user/emails` confirmed the Velu2k03 account's PRIMARY email is thalaveldaa1201@gmail.com (verified, public). The agent was already on the right account; nothing needed to move. The gh token now has scopes gist, read:org, repo, user, workflow.

- 07:31 to 07:34: env vars set in Vercel Production. AUTH_SECRET (64 chars) and CRON_SECRET (43 chars) generated and stored in ~/.config/sortes/production-env-secrets.txt (mode 600). A new Resend API key "Sortes Production" (sending_access) created; its value is in ~/.config/sortes/resend-production-key.txt (mode 600). All three (AUTH_SECRET, CRON_SECRET, RESEND_API_KEY) were ADDED to Vercel Production (Secret type, Production only), verified in the list; existing variables untouched; Preview NOT touched; no deployment triggered. Note: AUTH_SECRET is recommended-not-required (the app falls back to SUPABASE_JWT_SECRET, which Production already has); adding it invalidates sessions signed with the Supabase secret, but production has only the owner as a user. EMAIL_FROM was skipped (the default "Sortes noreply@sortes.resonantatlas.com" is fine). Temporary workspace copies of the secret files were DELETED after use.
- 07:39: MERGE DONE. It was NOT a fast-forward: the local `main` branch in ~/workspace/sortes points to f131206 from a DIFFERENT repo (sortes-galaxy). Do NOT use local main; the real target is origin/main. origin/main was 375c7a1 ("Merge pull request #62 from Velu2k03/sortes-merge-7"); merge-base ca083eb; 137 commits on the branch not in origin/main, 14 commits on origin/main not in the branch (the sortes-merge PRs #56 to #62). Merging origin/main into the transformation branch produced 11 conflicted files (birth-card, ChartsClient, daily, deck, faq, HistoryClient, page, ReportDetailClient, SpreadsClient, BranchedMenu add/add, Header with 12 hunks). Resolution: kept HEAD (the tested release candidate) throughout; main's versions of birth-card (birthCardNumber singular, does not exist), daily (TextType not imported), and SpreadsClient (getCard not imported, plus the exact bug HEAD fixed) would NOT have compiled; the Journal route is /journal NOT /history (verified on disk; src/app/history/ does not exist; /oracles exists, /credits does not); Header kept HEAD's anchored desktop popover plus /journal plus THEME_COLORS/syncThemeColor; BranchedMenu kept HEAD's Sortes gold/cream theme colours; page.tsx kept HEAD copy plus main's genuine sentence "Your first Quick Insight is free."; an auto-merged desktop BranchedMenu panel block in Header.tsx that referenced undefined `panel` state was also deleted. Verified on the merged result: lint 0, tsc 0, vitest 425/425 (the commit message records 380 passed / 45 skipped, 425 total; the two records agree on the total and differ on the pass/skip split, see section 14), build 0, no conflict markers, /journal plus /oracles build. Merge commit c84f92d (parents a9f7d08 plus 375c7a1). Then the transformation branch was pushed and origin/main fast-forwarded 375c7a1..c84f92d. Vercel auto-deployed on push to main. Deployment Ready, 35 s build, Nov 8 2026 7:41:06 AM GMT+8.
- 07:54: parity audit. The direction is INVERTED: Production is AHEAD of Preview, not behind. Vercel env vars: Production has 26, Preview has ZERO. Supabase: Production already caught up except custom SMTP (A1) and Redirect URLs (A2). Lemon Squeezy: test and live separate by design; only gap is the live webhook subscribing to order_created only (C1). Fourteen items must stay different between environments (database URLs, project URL/anon key/JWT secret, AUTH_SECRET, CRON_SECRET, Resend key, Lemon Squeezy API key / variant IDs / webhook secrets / webhook URLs, OpenRouter key, Supabase Site URL per-env, and the do-not-add list). The subagent could NOT verify live (Vercel MCP 403, no browser for subagents), so its env-var claims were reconstructions from docs, which later proved partly wrong (see section 14).
- 07:55: the owner approved A1 plus A2 plus C1 ("Yes, do A1, A2, and C1 (refunds too)").
- 07:58: C1 DONE. Lemon Squeezy live webhook 148741 now listens for order_created AND order_refunded (before: order_created only, "1 events"; after: "2 events"). Verified by reloading and reopening the edit panel. URL and signing secret unchanged. Test webhook 149521 NOT changed (its panel was opened in error and cancelled without saving).

- 08:00: A1 plus A2 DONE. A1: Supabase production custom SMTP SAVED and verified by reload (Enable custom SMTP on, Host smtp.resend.com, Port 465, Username resend, Sender name "Sortes", Sender email noreply@sortes.resonantatlas.com, password stored masked). The password is a NEW Resend API key named "Sortes Production SMTP" (sending access) created by the browser task and pasted into the SMTP field under the parent's explicit authorization for that specific transfer, NOT the "Sortes Production" key. A1 is PROVEN working: the 08:07 production sign-in email arrived from "Sortes noreply@sortes.resonantatlas.com" instead of Supabase Auth. A2: Redirect URLs total 9 (up from 8); https://-*velus-projects-27f81f38.vercel.app/** was MISSING and was ADDED; https://sortes.resonantatlas.com/** was already present; a distinct pre-existing entry https://sortes--*muse-velus-projects-27f81f38.vercel.app/** also exists. No existing entries removed.
- 08:17: Site URL change, owner approved ("Yes, change Site URL to sortes.resonantatlas.com"). DONE and verified by reload: production Supabase Site URL changed from https://sortes-muse-velus-projects-27f81f38.vercel.app/ to https://sortes.resonantatlas.com. Redirect URLs left unchanged (still 9). Staging not touched.

10. The two launch bugs (2026-11-08): found by the first production smoke test

10.1 Smoke test 08:19 (browser task 5de17600, 39 min): MIXED

Passing: deployment Ready; homepage loads (title "Sortes by Resonant Atlas | Cast the lots. Read your story."); FREE AI CHART WORKS (tested as guest on /charts, prefilled Jan 1 1990 8:00 AM Asia/Manila Female Ziwei: chart calculated, "Get interpretation (free)" returned an AI interpretation headed "FREE INTERPRETATION · PERSONALIZED · AI-GENERATED · WRITTEN WITH NVIDIA/NEMOTRON-3-ULTRA-550B-A55B:FREE", no payment).

Failing, two launch blockers:

1. Magic-link sign-in fails with ?auth=error (twice).
2. Oracle pack checkout fails to start ("Could not start checkout. Please try again." twice; Lemon Squeezy page never loaded; no payment attempted).

No settings, code, or env vars were changed by the test.

10.2 Bug 1: magic-link sign-in fails (root cause: missing production migration ledger)

Symptom. Two magic links (07:48 and 08:07, velu2k03@gmail.com) both redirected to https://sortes.resonantatlas.com/account?auth=error, still signed out. The second was opened in the same tab that requested it, so it is not a wrong-tab PKCE issue. The Supabase verify URL and redirect target were correct in both cases.

Exact chain of cause and effect:

1. src/app/auth/callback/route.ts exchanges the code, then calls getUserByEmail(email) after the exchange, before setting the Sortes session cookie.
2. src/lib/db.ts getUserByEmail calls ensureSchema() (db.ts:571).

3. ensureSchema calls runMigrations(pg) (db.ts:556).
4. In production allowApply is false (NODE_ENV=production, VERCEL_ENV=production, no SORTES_MIGRATE_PRODUCTION=1), so readAppliedVersions returns an empty set when the ledger table is missing (src/lib/migrations.ts, `if (!createLedger) return new Set()`).
5. runMigrations finds all four migration files (001 baseline, 002 indexes_constraints, 003 drop_checkout_nonces, 006 session_version) "pending" and THROWS: "Pending database migrations must be applied by an operator, not by the running app" (src/lib/migrations.ts:118-124).
6. The callback's catch returns fail, so the user lands on /account?auth=error (src/app/auth/callback/route.ts:51-52).

Proof. The production backup taken 2026-11-07 23:06 UTC (after the SQL fixes) contains COPY data for exactly 7 app tables and NO public.schema_migrations table at all, no CREATE TABLE and no COPY for it (verified by inspecting the decrypted dump hidden_files/backup-verify/sortes-20261107-230617.dump). The SQL fixes were applied through the Supabase SQL Editor, which does not populate the app's ledger table.

Why it fits. Deterministic, so both links fail identically regardless of tab. Production-only: Preview and staging auto-apply migrations (allowApply true), so their ledgers are populated. The guest free chart works because it is DB-free for guests (src/app/api/chart/interpret/route.ts: the session/DB block is skipped when there is no session), and the homepage is static and DB-free. Consequence stated in the diagnosis: this is not only a sign-in bug. EVERY DB-backed operation in production failed the same way (sign-in, balance, history, readings). Sign-in is just the first DB-backed operation the smoke test exercised.

The deviation that caused it. The PRODUCTION-CHANGE-PLAN procedure (migrate CLI with SORTES_MIGRATE_PRODUCTION=1, which updates the ledger) was NOT followed live. The SQL Editor route was used instead at 03:09. The SQL was applied correctly; the ledger was never populated. The plan's deploy-order gate (verify the ledger shows 001, 002, 003, 006 before merge/deploy) was not executed as a gate, because the plan assumed the CLI had run.

Secondary, latent defect in the same route. The callback never read the `sb_flow_id` query param and called exchangeCodeForSession(code) with no options (route.ts:29,33), falling back to a deprecated legacy fixed-key verifier cookie. Verified in the installed SDK (supabase-js 2.118.0, @supabase/ssr 0.12.7): signInWithOtp creates a PKCE flow, stores the verifier, and appends the flow id to the redirect URL, so the callback URL is .../auth/callback?sb_flow_id=. The server-side exchange can only look up the flow-specific verifier slot when given the flow id. The app therefore relied on a deprecated dual-write fallback. The file states explicitly this is fragile and is the correct fix per the Supabase SSR pattern, but it is NOT the cause of the current failure (the ledger is). Also, route.ts:34 swallowed the exchange error with no log.

Fix (parent session record, verified live). The owner approved "fix both bugs" at 08:31. Ledger fix DONE 08:33 (browser task 43a894f5): via the Supabase SQL Editor on production, public.schema_migrations was created and the four rows inserted; a verification SELECT returned exactly 001 baseline, 002 indexes_constraints, 003 drop_checkout_nonces, 006 session_version. No migration SQL files were re-run; no RLS, users, or other tables touched; staging untouched. When Supabase warned the new table had no RLS, the browser chose "Run without RLS" (accepted: the ledger is internal, accessed via the privileged POSTGRES_URL connection, not the anon key).

Code fix plus Google button (commit 1c19e68, subagent def3e2a9). Four files changed:

1. src/app/auth/callback/route.ts: reads `sb_flow_id` and passes `{ flowId }` to exchangeCodeForSession (only when present; verified against installed supabase-js 2.118.0 source, GoTrueClient.ts:1412); exchange failures now logged ("auth callback exchange failed:" with message plus code); user-facing behaviour unchanged (fail goes to /account?auth=error, success to /account?auth=ok); session bridging and cookie logic untouched; a comment notes the route serves both magic-link and Google OAuth.
2. src/app/account/AccountClient.tsx: added a "Continue with Google" button (existing btn-ghost style, gold "G" mark) above the email methods, shown for both Sign in and Create account modes; calls supabase.auth.signInWithOAuth({ provider: "google", options: { redirectTo: /auth/callback }}) via the existing getSupabaseBrowser() client; no new dependency, no hardcoded URL; signup copy no longer says "There is no Google sign-in."
3. src/app/faq/page.tsx: "How do I sign in?" now lists Google first, then email link, then password.
4. src/app/account/AccountClient.test.ts: the old test pinned "no Google sign-in"; it now pins exactly one signInWithOAuth call with provider "google" plus redirectTo origin plus /auth/callback, asserts the button copy, plus 2 new tests.

Verification: lint 0, tsc 0, vitest 382 passed / 45 skipped (427 total, up from 380/425), build 0 (/account and /auth/callback build). Pushed: transformation branch c84f92d..1c19e68, and main fast-forwarded c84f92d..1c19e68. Vercel deployed.

10.3 Bug 2: Oracle checkout fails (root cause: the saved live key value was damaged or wrong)

Symptom. On https://sortes.resonantatlas.com/oracles, as a guest, clicking Checkout for First Light ($3.99, 5 Oracles), entering velu2k03@gmail.com, and clicking Checkout showed "Could not start checkout. Please try again." twice (08:19). The Lemon Squeezy checkout page never loaded. No payment attempted.

Code path, verified by direct reading. src/app/api/checkout/lemonsqueezy/route.ts:11-13: the 503 gate (lemonConfigured()) did NOT trigger, so LEMONSQUEEZY_API_KEY, LEMONSQUEEZY_STORE_ID, and all three variant IDs are present and non-empty in Production. The failure is inside createCheckout, not a missing variable. route.ts:77: the 500 response is `{ error: "Could not start checkout. Please try again." }`. src/lib/lemonsqueezy.ts:114: createCheckout POSTs to ${API_BASE}/checkouts (API_BASE defaults to https://api.lemonsqueezy.com/v1). A non-OK response throws "Lemon Squeezy checkout failed (status): ..." (lemonsqueezy.ts:164-171). The exact API error is logged server-side: the `checkout-failed` event with status and truncated response body, plus the `checkout-route-error` line in the route catch.

What the logs said (parent session record, verified live 08:59, browser task 10262461). Vercel runtime logs for deployment dpl_8o8AxqrtkN7JZYKGJrDSiyfGrCdD contain checkout-failed and checkout-route-error lines, every one the same error: Lemon Squeezy returned HTTP 401 Unauthorized, "Unauthenticated." Five attempts in two clusters (two around 08:50, three around 08:56), not just two. A 401 means the bearer token is missing, malformed, revoked, or expired. A wrong store or variant ID returns 404 or 422; a wrong mode or account usually returns 403 or 404. So the token string the function sends is not a valid Lemon Squeezy key. An unrelated error in the same window: at 08:55:58.22, /api/chart/interpret logged a model-failed event (openrouter/free, timed out after 25000ms); chart and reading model calls succeeded shortly after (08:56:23 and 08:57:37).

Claude's diagnosis (09:00, Claude Code 2.1.319, hidden_files/claude-checkout-401-diagnosis-2026-11-08.md). The code is CORRECT: lemonsqueezy.ts:105 reads process.env.LEMONSQUEEZY_API_KEY?.trim() at request time (not baked in at build); line 117 sends `Authorization: Bearer ${apiKey}`; Content-Type and Accept are both application/vnd.api+json (lines 118-119); the base URL is https://api.lemonsqueezy.com/v1 when LEMONSQUEEZY_API_BASE is unset (lines 10-11); the body is a JSON:API checkouts object with store id, variant id, checkout_data.email and custom, and product_options.redirect_url; there is no test/live switch in the body, mode comes only from which key is sent. lemonConfigured() (lines 30-38) only checks the five env vars are non-empty and cannot catch a bad key. Ranked causes: (1) the new key never reached the running function (most likely): wrong scope, an older Production entry with the same name, deployment built before the edit was saved, or the production alias still pointing at an older deployment; (2) the pasted value is damaged: truncation, a `Bearer` prefix, wrapping quotes, or a missing character (Lemon Squeezy keys are long JWTs, roughly 900 or more characters, so truncation is easy to miss); (3) wrong-mode key, created while the dashboard Test mode toggle was on; (4) the key was revoked or replaced; (5) a code problem is very unlikely. Claude could not check the Vercel side because the Vercel MCP call (list_projects) was denied permission in that session.

What was ruled out (parent session record, verified live 09:08, browser task a9b8c06c). All three checks were FINE. Vercel: two LEMONSQUEEZY_API_KEY entries by design (Production-only updated 08:44, Preview-only 7 Nov). The Production deployment is 8o8Axqrtk, sortes.resonantatlas.com serves it, built about 3 minutes AFTER the env var update (no stale alias). Lemon Squeezy: "Sortes Production Live" exists, live mode, expires 2027-05-08 (a second Resonant Atlas store #473370 also exists; the active one is #244487). So scope, alias, and key-mode are ruled out. The only unknown was the masked VALUE in Vercel (it could be damaged or the wrong, older key). The first key "Sortes" (created 3 Nov 2026) is proven INVALID (401). The test key "Sortes Preview 2" (Preview env, expires 2027-05-07) is proven working, but only as a test key. There was NO record anywhere of a live-mode key ever being created or verified before this day; the parity audit's "live-mode key" claim was a doc reconstruction, never a live read.

Fix (parent session record, verified live). A fresh live key "Sortes Production Live 2" was created (1,035-character JWT, copy button used, clipboard re-copied after an overwrite), pasted into Vercel Production LEMONSQUEEZY_API_KEY with the length verified at 1,035 characters (no spaces, quotes, or "Bearer " prefix), and the site redeployed (BLdAJQ3ja, Ready 09:13). CHECKOUT FIXED 09:15 (browser task d9aa72ce): the checkout page loads on the FIRST attempt (First Light $3.99, Lemon Squeezy page at pay.resonantatlas.com, Subtotal/Total $3.99, Pay button, card/PayPal/Google Pay/Alipay/Cash App Pay; no payment made). Root cause was the first key's saved value being damaged or wrong. Note: the "Top up Oracles" dialog did not appear (the flow went straight to Lemon Squeezy) and the checkout Email field pre-filled futureai2077@gmail.com from browser/Link saved info, not velu2k03@gmail.com; the receipt email would need changing on the checkout page. The side effect recorded by Claude also applies: getOrder (lemonsqueezy.ts:193-213) uses the same key and returns null on any non-OK response, so until the key works, paid orders will not grant credits either (the webhook refuses to fulfil and returns 500 so Lemon Squeezy retries).

10.4 Google sign-in enablement (parent session record, verified live)

The owner asked at 08:32: "also can you add, sign in with google, bcz i already setup in supabase, look there." The Supabase Google provider check (08:33, browser task 3d969df6, read-only) found: production project

providers, Email ENABLED, GitHub ENABLED, everything else disabled. Google: DISABLED (enable switch off), Client Secret present (masked), callback URL https://adgputwbdtdmgkiswtnz.supabase.co/auth/v1/callback.

The Google enable attempt (08:33 to 08:34, browser task 1a3d5560) FAILED and was blocked: the Google Client IDs field contains the invalid value "Sortes-muse". Supabase flags it red: "Invalid characters. Google Client IDs should be a comma-separated list of domain-like strings." A valid Google Client ID looks like .apps.googleusercontent.com. The browser turned the enable switch ON, clicked Save, the dialog refused to save; per the parent's instruction it cancelled without saving, leaving Google DISABLED and all other providers untouched.

The owner then asked the agent to get it from the browser ("can u do in ur brwser and get it?"). Browser task f8bb140b (08:39 to 08:41) signed in to Google Cloud Console as velu2k03@gmail.com, found the OAuth 2.0 Client ID named "Sortes" (Web application, created 7 November 2026, status Enabled) in the RAG-ChatBot project (rag-chatbot-498522) under APIs and Services, Credentials. It used the real Client ID (ending in .apps.googleusercontent.com) and did not copy or use the Client Secret.

One necessary fix in Google Cloud: that OAuth client's Authorised redirect URIs only listed another Supabase project's callback, not production's. The browser added the production callback URL as a second redirect URI, saved it ("OAuth client saved"), and verified after reopening that both URIs are stored. Nothing else in the client was changed, and the other URI was left untouched.

In Supabase production, the browser replaced the invalid Client IDs value "Sortes-muse" with the real Client ID, left the Client Secret unchanged, turned ON "Enable Sign in with Google", and saved. Supabase showed "Successfully updated settings", and Google now shows as ENABLED in the providers list. The browser reopened the Google provider to verify the toggle stayed on and the new Client ID persisted. Callback URL: https://adgputwbdtdmgkiswtnz.supabase.co/auth/v1/callback. Google Cloud notes settings may take 5 minutes to a few hours to take effect. The staging project and all other providers were not touched. The Client ID and Client Secret values are intentionally not recorded in this document.

Password sign-in EXISTS in the app (a "Password" tab on the account page, app scrypt), but the test-account password is unknown (auto-generated during testing). The owner later asked (09:17) "what is the password? for the velu2k03? in the sortes" and "what u put". The honest answer given: no password was ever set by the agent; it was auto-generated during testing and neither the owner nor the agent knows it. That is why the magic-link path is used. If the owner wants a password he knows, it can be set on the account, but the current one cannot be told to him because it is not known.

10.5 Smoke test re-run (08:49 to 08:56, browser task 80baa371): 4 of 5 pass, then 5 of 5

Homepage loads: YES. "Continue with Google" button: PRESENT on the /account sign-in page (Google sign-in itself was not attempted). Magic-link sign-in: WORKS. The link was requested once for velu2k03@gmail.com, opened in the same tab that requested it, and landed on /account?auth=ok signed in as velu2k03@gmail.com. Oracle balance shown: 128 Oracles, matching the expected balance. Free AI chart interpretation: WORKS. The prefilled example (1990-01-01, 08:00, Manila, Female, Ziwei) calculated without error ("Ziwei chart. Life: Sun, Blessing. Zodiac: Snake."). As a signed-out guest the interpretation correctly required 1 Oracle, but as the signed-in user the button read "Get interpretation (free)" and returned a full AI

interpretation without error, headed "FREE INTERPRETATION · PERSONALIZED · AI-GENERATED · WRITTEN WITH NVIDIA/NEMOTRON-3-ULTRA-550B-A55B:FREE". The balance remained 128 Oracles afterward; nothing was deducted. Oracle checkout: FAILED at 08:56 ("Could not start checkout. Please try again.", retried once, stopped per instructions). After the fresh-key fix at 09:13, checkout PASSED on the first attempt at 09:15. No card details were entered and no payment was attempted at any point.

11. Phase I acceptance (2026-11-08 09:18): CONDITIONAL GO, 90/100

Production deployment BLdAJQ3ja, commit 1c19e68, Ready 09:13, live site https://sortes.resonantatlas.com. Verdict CONDITIONAL GO, 90/100. The score is unchanged from the revised 90; the verdict moved from CONDITIONAL NO-GO to CONDITIONAL GO because the deploy is done and the live proof is in.

Per-area: Security 9, Payments 9, Balance 10, Postgres 10, Auth 9, AI 8, UI/UX 9, QA 9, SEO 8, Deployment 9. Sum 90. No area changed; the deploy confirms the 90 rather than raising it. Each area is held below 10 by a specific named gap: Payments needs a real production payment; Auth needs Google and password proven on production; AI needs the paid 3-card reading; Deployment needs G12 executed and G2 done; UI/UX needs G11 green; QA needs the G10 console sweep.

Gates at Phase I: GREEN 9 (G1, G3, G4, G5, G6, G8, G9, G13, G14), AMBER 4 (G2, G7, G10, G12), RED 1 (G11). Flips since the revised doc: G6 AMBER to GREEN (production magic-link sign-in proven 08:56, /account?auth=ok, balance 128); G13 AMBER to GREEN (AUTH_SECRET, CRON_SECRET, RESEND_API_KEY set in Vercel Production 07:34, Lemon Squeezy live key set and redeployed, live variant IDs and store ID verified).

The Phase I verifier also checked live itself (read-only): origin/main is at 1c19e68; homepage, /oracles, and /account all return HTTP 200; the /oracles server HTML (33.6 KB) contains no prices or pack names, confirming roast R3 (client-rendered pricing) is still open as a follow-up, not a blocker.

Conditions for full GO:

- C1: the owner does the real-device 390px mobile test (G11).
- C2: a paid 3-card reading is proven live using the existing Oracle balance, no real payment, including the free first follow-up.
- C3: full console-error sweep (G10).
- C4: rollback drill (G12).
- C5: staging migration test (G2).

Other open follow-ups recorded: Google sign-in end to end (once Cloud settings propagate); docs fix for STAGING.md and db.ts header (session mode vs transaction mode); R3 pricing server-rendering; staging concurrency soak; Phase D measurement; the 170 s vs 120 s watch item.

12. Score trajectory and gate history

12.1 Score trajectory

Report	Date	Score	Verdict
Muse roast	2026-11-05	52	Roast, not a launch verdict
Argon roast	2026-11-05	51	Roast, not a launch verdict
Transformation final report	2026-11-05	78 to 82	Code quality, not launch readiness
Release readiness review	2026-11-06	58	NO-GO
Phase 6	2026-11-06	80	CONDITIONAL NO-GO
Phase 7	2026-11-07	81	CONDITIONAL NO-GO
Phase 8A	2026-11-07	85 headline, 84 by area sum	CONDITIONAL NO-GO
Phase H gate pack	2026-11-07	86 headline, 85 by area sum	CONDITIONAL NO-GO
Recomputed	2026-11-08 about 01:45	88	CONDITIONAL NO-GO
Revised readiness	2026-11-08 07:30	90	CONDITIONAL NO-GO
Phase I acceptance	2026-11-08 09:15	90	CONDITIONAL GO

Per-area scores where given (each area 0 to 10):

- Readiness review 58: Security 8, Payments 5, Balance 6, Postgres/SQL 4, Auth 5, AI 4, UI/UX 8, Desktop/mobile QA 7, SEO 8, Deployment 3.
- Phase 6, 80: Security 9, Payments 7, Balance 9, Postgres 9, Auth 8, AI 6, UI/UX 9, QA 9, SEO 8, Deployment 6.
- Phase 7, 81: Security 9, Payments 9, Balance 9, Postgres 9, Auth 7, AI 5, UI/UX 8, QA 9, SEO 8, Deployment 8.
- Phase 8A, 84 by sum: Security 9, Payments 8, Balance 10, Postgres 9, Auth 7, AI 7, UI/UX 9, QA 9, SEO 8, Deployment 8.
- Gate pack H, 85 by sum: Security 9, Payments 9, Balance 10, Postgres 9, Auth 8, AI 6, UI/UX 9, QA 9, SEO 8, Deployment 8.
- Recomputed 88: Security 9, Payments 9, Balance 10, Postgres 9, Auth 9, AI 8, UI/UX 9, QA 9, SEO 8, Deployment 8.
- Revised 90: Security 9, Payments 9, Balance 10, Postgres 10, Auth 9, AI 8, UI/UX 9, QA 9, SEO 8, Deployment 9.
- Phase I 90: same as revised, unchanged.

Test counts over time, as reported: transformation 160/160 in 26 files; Phase 6 210/210 in 32 files; Phase 7 223/223 in 32 files; Phase 8A clean-tree 237/237 in 34 files at e6a5fb5; mission Phase B 274/274 then 293/293; Phase D/E 350/350; Phase G 386/386 then follow-up 396/396; fix round 413/413; hang fixes 416/416, 419/419, 423/423, 425/425 at b19ec8a; Phase I 382 passed plus 45 skipped, 427 total, at 1c19e68.

12.2 Gate history (Phase H G1 to G14)

Note the naming collision: the Readiness Review and Phases 6 and 7 use a different G1 to G5 set from the Phase H G1 to G14 set. Do not mix them.

Gate	Pack 2026-11-07	Revised 2026-11-08 07:30	Phase I 2026-11-08 09:15
G1 Production backup plus restore verified	RED	GREEN	GREEN
G2 Migrations tested on staging	AMBER	AMBER	AMBER
G3 RLS reviewed and tested	GREEN code / AMBER applied	GREEN	GREEN
G4 No critical/high security issues	GREEN	GREEN	GREEN
G5 Credit/payment integrity verified	GREEN local	GREEN	GREEN
G6 Auth verified	AMBER	AMBER	GREEN
G7 AI failures do not charge	GREEN code / AMBER live	AMBER	AMBER
G8 Preview E2E passes	RED	GREEN	GREEN
G9 Build plus lint pass	GREEN	GREEN	GREEN
G10 No important console errors	AMBER	AMBER	AMBER
G11 Mobile tests pass	RED	RED	RED
G12 Rollback documented plus executable	AMBER	AMBER	AMBER
G13 Production env vars verified	AMBER	AMBER	GREEN
G14 Production changes have clear reviewed impact	GREEN	GREEN	GREEN

13. Failure catalog (condensed)

This section is the index. Detail for each item is in the section named.

ID	Failure	Root cause	Fix	Section
R1	Free reading paywall flip	Render race, free state arrives late	One question-first flow, free honoured server side	2.2
R2	Free chart interpretation fails twice	No diagnostic, no fallback	Shared AI client, retry/backoff, static fallback	2.2
R3	Pricing not agreed (client-rendered)	Prices absent from server HTML	Not fixed; still client-rendered at Phase I	2.2, 11
R4	credits-migrate mints Oracles	No cap, no one-time guard	Route deleted	2.2
R5	Demo checkout grants product free	Env-missing path granted product	Demo path deleted	2.2

ID	Failure	Root cause	Fix	Section
R6	Identical sample readings	Shared template	Distinct sample per spread	2.2
R7	Currency confusion	No single currency named	Oracles everywhere, USD line	2.2
R8	Guest journal localStorage only	No export, no warning	Warning plus JSON and Markdown export	2.2
R9	76 animations, three runtimes	No code splitting	Dead components deleted, splitting added	2.2
R10	Push prompt promises nonexistent reminders	Feature promised, never built	PushPrompt deleted	2.2
R11	No social proof	None existed	None invented, by rule	2.2
R12	Reports sample only skeleton	No full sample	Not recorded as fixed	2.2
R13	Deck card detail has no URL	Dialog only	78 static /deck/[slug] pages	2.2
R14	Sortes never explained	No homepage line	Not recorded as fixed	2.2
R15	Guides with no author/date/read time	Missing metadata	Not recorded as fixed	2.2
R16	Account page two products, one label	Unequal paths	Equal Create / Sign in paths	2.2
R17	Header/footer disagree with URLs	Stale routes	Renames with redirects	2.2
R18	Hero stock moon, low contrast	Placeholder visual	Homepage restrained, plain gold H1	2.2
N1	Silent JSON fallback	No fail-fast guard	Production fail-fast guard	4
N2	OTP length mismatch risk	Setting vs provider default	Closed by evidence (8 digits, 1 hour)	4
N3	Rate-limit gaps	Per-route maps, unrated routes	Shared limiter everywhere	4
N4	Deletion needs only session cookie	Non-revocable 30-day JWTs	Delete re-auth plus pwdVer (migration 006)	4
N5	Balance not checked before AI	Spend after generation	402 before generateChat on all four AI routes	4
N6	Guest free use client-trusted	Client-claimed flags	Accepted risk, observability log added	4
N7	Follow-up lost-update race	Check then insert, not atomic	Single Postgres transaction	4

ID	Failure	Root cause	Fix	Section
N8	Guest reports never migrated	Second free after sign-in	Known gap, 1 Oracle per user, not fixed	4
N9	Webhook no error handling or reconciliation	Bare 500, no alerting	Try/catch, structured logging, reconcile script	4
N10	Sessions coupled to Supabase secret	Single shared secret	AUTH_SECRET recommended as dedicated secret	4
N11	No indexes or CHECK constraints	Schema without constraints	Migration 002 indexes plus CHECK credits >= 0	4
N12	Local fallback unsafe even for dev	Unsafe branch	Fail-fast guard for production	4
JSONB	Double-encoded JSONB rows	`${JSON.stringify(x)}::jsonb` under postgres.js	Central jsonbParam(), migration 002 repair	5
Hang	300 s stalls, 8.5% of invocations	Supavisor transaction-mode pipelining suspected, unproven	4 defense-in-depth commits plus session-mode switch	8
SMTP	2 emails/hour cap, then wrong password	Built-in sender cap; wrong value entered 14:16	Custom SMTP via Resend; owner re-entered key 15:05	8.5
8A-1	Magic-link redirect lands on root	Supabase allow-list gap, not code	Dashboard allow-list entries added	7.9
8A-2	Paid reading fails after 300 s	Hang upstream of AI call	Hang diagnosis rounds (section 8)	7.9, 8
8A-3	Purchase credited to Link email account	Webhook attributed by order email only	Attribution by signed-in user id first	7.9
8A-4	Auth submit button sticks	One shared busy flag, unbounded awaits	Per-action flags, 10 s fetch bounds	7.3
Bug 1	All magic-link sign-ins fail in production	SQL Editor route left the migration ledger empty	Ledger populated 08:33; callback flowId fix in 1c19e68	10.2
Bug 2	Checkout fails, Lemon Squeezy 401	First live key value damaged or wrong	Fresh live key "Sortes Production Live 2", redeploy BLdAJQ3ja	10.3
Google	Google provider disabled, invalid Client ID "Sortes-muse"	Placeholder value, never a real Client ID	Real Client ID from RAG-ChatBot project, redirect URI added, provider enabled	10.4
Prod down	Live site DOWN after password reset	Owner reset production DB password at 02:51 before redeploy	Vercel POSTGRES_URL updated 02:58; redeploy restored service	9.3

14. Decisions the owner approved

Only approvals evidenced in the record are listed. Where the file gives exact words, they are quoted. Where it only records an order, the wording is paraphrased and marked as paraphrase.

Date	Decision	Wording
2026-11-04	PixelCard approval	Approval that restored the gold PixelCard on the popular card. Exact wording not given.
2026-11-05	Pricing approved	Live pricing stays 5/$3.99, 12/$7.99, 30/$14.99, flat 1 Oracle per feature. Exact wording not given.
2026-11-06 10:00+	Phase 6 ordered	Owner accepted the Readiness Review NO-GO (58/100) and ordered Phase 6. Paraphrase.
2026-11-06 14:34	Phase 7 ordered	Complete the preview deployment, verify staging, E2E-test, prepare the production backup plus change plan, re-verify. No push/merge/deploy to Production, no production data/migration/RLS/env changes. Branch push explicitly authorised. Paraphrase.
2026-11-06 23:05	AI fix	"fix both with free models". No paid AI models, no price or monetisation changes, flat 1 Oracle per reading stays.
2026-11-07	"try other free models first"	Owner chose free models first. No credits bought, no paid models.
2026-11-07 01:59	Phase 8A ordered	Resolve A1 plus A2 from the Phase 7 report, then stop. No production backups, migrations, RLS, or deployment without separate approval. Preview/staging only, no paid AI, preserve all customer data. Paraphrase.
2026-11-07 02:05	Mission Phases A to I ordered	Merge and deploy to production are authorized ONCE all mandatory gates are GREEN. Production migrations, RLS changes, and env changes happen only after proving the exact change in staging, inspecting the SQL and its expected effects, and verifying backup plus rollback. Paraphrase.
2026-11-07 03:05	Push hold	No push until the parent confirms Phase 8A E2E complete. Later push cleared and branch pushed as c7f2ba4 at about 08:37.
2026-11-07 22:28	One-retry rule	"if something does not work, do NOT try it again and again, diagnose from logs, code, internet, GitHub, docs".
2026-11-08	"finish all"	Owner said "finish all". Recorded as his go-ahead to complete the release: set the remaining env vars, merge, deploy, smoke test, and finish the work. It does not override standing rules. It does not authorize a price change, a paid model, or an unapproved production change.
2026-11-08 00:42	Session-mode staging test	Owner tapped "Yes, test the session-mode connection on staging". Scope staging/Preview only. Production not touched.
2026-11-08 01:16	Staging password reset plus session-mode switch	Owner tapped "Yes, reset the staging password and switch to session mode".

Date	Decision	Wording
2026-11-08 01:34 / 01:36	Test purchase approvals	Parent approved the cart 01:34 and the payment 01:36; the decision log states the owner approved the payment in the browser approval flow. Test mode only, First Light $3.99, order lemonsqueezy:9973511.
2026-11-08 02:51	Production DB password reset by the owner himself	The owner reset the production database password himself at 02:51, before the parent do-not-reset message landed. Recorded as an action, not as a quoted approval.
2026-11-08 07:55	A1 plus A2 plus C1	"Yes, do A1, A2, and C1 (refunds too)".
2026-11-08 08:17	Site URL change	Site URL changed to https://sortes.resonantatlas.com, owner approved 08:17.
2026-11-08 08:31	Fix both launch bugs	Owner approved fixing both bugs (ledger and checkout).
2026-11-08	Production launch actions under "finish all"	AUTH_SECRET, CRON_SECRET, RESEND_API_KEY set in Vercel Production 07:34; Lemon Squeezy live key set; merge to main c84f92d; deploy BLdAJQ3ja Ready 09:13. Recorded as done under the "finish all" go-ahead, not as separate quoted approvals per item.

No approval for tiered pricing, paid AI models, a paid OpenRouter fallback, a $10 OpenRouter credit purchase, production migrations as a blanket approval, RLS as a blanket approval, the Postgres 17.11 upgrade, a Pro upgrade, a real-money test purchase, or partner contact is recorded in the files. Those items are repeatedly listed as blocked or needing per-run approval.

15. Contradictions and stale claims found (honest record)

These were found by the revised readiness review and by the evidence briefs. They are preserved here so no future reader quotes a stale claim as current fact.

1. **Score headline vs area sum.** Phase 8A headline 85, area sum 84. Gate pack headline 86, area sum 85. Both headlines are exactly 1 more than their area sums. The revised readiness doc avoids the error by showing the arithmetic in full; 88 and 90 are reproducible from their tables.
2. **Gate pack "No new dependencies".** The claim that the package.json / package-lock.json diff is empty across the whole stack is stale. Commit 1c690fa bumped postgres.js from ^4.0.0 to ^4.1.0. Release notes must state the bump.
3. **STAGING.md and db.ts vs deployment.** STAGING.md line 91 says app connections use the transaction pooler port 6543; lines 201 to 203 say do not switch to the session-mode pooler 5432 because the free tier would exhaust direct connections; the db.ts header line 15 says prepare:false is required because transaction mode does not support prepared statements. Fact: the app switched to session mode 5432 on Preview and Production. Docs and code comment directly contradict the current deployment. Fix still owed at Phase I.
4. **Production env var count.** Gate pack section 5 says 22 vars present, last verified 2026-11-06. ENVIRONMENT.md audit and tracker say 23 set. Phase I section 3 says the count discrepancy 22 vs 23 vs 26 is resolved: Production has 26 env vars per the parity audit. Phase 7 report section 2 says

Production 22 vars, and the earlier count of 23 was a counting artifact of the virtualized dashboard list. These three counts cannot all be snapshots of the same state without a change in between; Phase I resolution to 26 is the latest stated count.

5. **Gate pack branch state stale.** Pack section 1 says the origin branch is e6a5fb5 and 52 local commits ahead, NOT pushed, push hold in force. Fact at revised readiness time: the branch was pushed, current HEAD d54a639, push hold cleared. Origin main still 375c7a1, correct.
6. **Gate count in the pack.** Pack section 7 lists G3 and G7 as split GREEN/AMBER rows, and section 8 says GREEN 5, AMBER 5, RED 3, total 13 if split rows are counted once, or 14 if split rows are counted as two gates each in part. Revised Readiness section 3.2 restates the pack as GREEN 5, AMBER 5, RED 3, total 14, without resolving the split counting. Flagged as ambiguous, not as a verdict change.
7. **G3 sign-in verdict flips.** Phase 6 says G3 GREEN based on OTP 8 digits from a Supabase setting; Phase 7 says G3 AMBER because E2E proved the delivered email contains only a magic link, never a code. A setting was never behaviour.
8. **Test count at Phase I.** Phase I section 3 says vitest 382 passed plus 45 skipped, 427 total, at 1c19e68, up from 380/425. Revised Readiness says 425/425 at b19ec8a. The 382 plus 45 equals 427, which is 2 more than 425, and the "up from 380/425" phrasing is unclear. No explanation in the files for the 2-test difference. Separately, the merge commit message records 380 passed / 45 skipped (425 total) while MEMORY.md records 425/425; the totals agree and the pass/skip split differs. Flagged, not resolved.
9. **Checkout modal existence.** Re-test task 2 records E2 checkout modal FAIL as specified but NOT a product bug because no checkout modal exists; a fresh-profile run records E2 checkout modal focus trap PASS, correcting the attempt 3 claim that no checkout modal exists, because the modal does exist. Both statements are in the decision log with no code change reconciling them.
10. **Parity audit vs bugs diagnosis on the Lemon Squeezy live key.** The parity audit table lists Production LEMONSQUEEZY_API_KEY as "Set (live-mode key)". The bugs diagnosis states the first key "Sortes" is proven INVALID (401), states there is NO record of a live-mode key ever being created or verified, and states the parity audit's live-key claim is explicitly a reconstruction from docs, NOT a live verification (the Vercel MCP API returned 403, so the actual Production value was never read). The parity audit's claim must not be quoted as verified.
11. **Parity audit vs bugs diagnosis on migrations.** The parity audit lists migrations 001/002/003/006 as "Applied 2026-11-08 03:09" and "Match". The bugs diagnosis proves the SQL was applied but the public.schema_migrations ledger was never populated, so the in-app verify-only guard throws on the first DB call. "Applied" is true at the SQL level and false at the ledger level; the parity row overstates readiness.
12. **Session-mode recommendation vs parity audit on production state.** The recommendation's section 3 table lists production as transaction mode with timeouts and migrations not applied. The parity audit records the session-mode switch at 02:58 and timeouts plus SQL at 03:09 on 2026-11-08. This is a timing difference (the recommendation predates the switch), but any reader of the recommendation alone would misstate production state.
13. **Phase A security audit vs Phase B review on migration 005.** Phase A (HEAD ad68ce7) states 005 is not written. Phase B (HEAD 58dbe19) states 005 is written, locally tested, and its test passes 6/6. Chronological progression, not a true contradiction, but the two files must not be quoted together without dates.

14. **Phase A security audit C33 vs bugs diagnosis on MIGRATION_FILES.** Phase A states the generated list contains only 001 to 003. The bugs diagnosis states it lists 001, 002, 003, 006. Same progression (006 added by commit 7e85b6b, an ancestor of the Phase B base).
15. **Architecture audit (2026-11-05, main 375c7a1) vs Phase A/B on tests.** The architecture audit states there is no test script, no test runner, and no test directory. Phase A cites 223 tests at HEAD ad68ce7 and Phase B ran 274 tests. Progression on the branch, not a contradiction, but the architecture audit's claim is stale for the branch.
16. **Roast notes vs their own correction.** The roast's live pass reported pricing and reports mismatches against code; the 07:32 UTC correction the same day withdrew both after a direct re-check. The withdrawn claims must not be quoted; the score stayed 52/100.
17. **staging-preview-env.md vs the session-mode switch.** The staging env file (2026-11-06) documents the staging POSTGRES_URL as the transaction pooler on port 6543. The parity audit records both Preview and Production on session mode 5432 by 2026-11-08. The env file's pooler port is stale.
18. **Phase A product audit vs Phase B review on charts-check.** The product audit treats charts-check as a live gate; the Phase B review proves it has been red since commit 1c0bd9f (stale code-preview assertion) and that any claim it passes on the branch is false.
19. **Roast baseline vs current test count.** The roast says no test script and no test files. Current state is 425 tests passing at b19ec8a. Not a contradiction; it is the transformation fixing the finding. Listed in the revised readiness doc to prevent mistaking the roast baseline for current state.
20. **ENVIRONMENT.md is stale as of 2026-11-08.** It says AUTH_SECRET, RESEND_API_KEY, and CRON_SECRET are missing in Production and Production has 23 variables. All three were set in Vercel Production 07:31 to 07:34 on 2026-11-08, and the parity audit records Production at 26 variables with Preview still at 0. It also says LEMONSQUEEZY_API_KEY is set, which was true in the dashboard but the value proved invalid (HTTP 401 on every checkout attempt) and was replaced twice that day.
21. **BACKUP-RECOVERY.md presents the VM cron as primary and GitHub Actions as fallback.** Live state inverted that: the VM cron 03:00 run on 2026-11-08 FAILED (age keypair still missing), and direct psql/pg_dump from the VM is blocked; the GitHub Actions run 42423673087 at 07:07 produced the verified backup. The installed workflow file's own header states the runner-based backup "is the production backup until that permission is enabled". The doc's fallback rationale (public repo scheduled workflows auto-disable after 60 days of repo inactivity, no delivery SLA) still stands as a risk but does not match the current primary.
22. **PRODUCTION-CHANGE-PLAN.md says the release candidate branch at 6381be2 is "not yet merged".** It has since merged (commit c84f92d, 2026-11-07 23:39 UTC). The plan's section 4 procedure (migrate CLI with SORTES_MIGRATE_PRODUCTION=1, ledger updated by the runner) was NOT followed live: all six files were applied to production via the Supabase SQL Editor at 03:09 on 2026-11-08 and the migration ledger was NOT updated. The plan's baseline (6 tables, RLS disabled on all 7) is also now out of date: production has 7 tables (free_readings created) and RLS enabled on all 7.

16. Open items at the end of Phase I (2026-11-08 09:18)

Phase I conditions for full GO (C1 to C5) plus follow-ups:

- **C1.** The owner does the real-device 390px mobile test (G11 RED). Includes SlideCommit touch drag and P1-3 header tightness. The agent browser cannot emulate a real-device finger test.

- **C2.** A paid 3-card reading is proven live on production, using the existing Oracle balance, no real payment, including at least the free first follow-up, with exactly 1 Oracle spent and the reading saved to the journal. Follow-ups unmeasured. Phase D measurement unrun.
- **C3.** Full console-error sweep on the live site (G10 AMBER). Smoke tests reported no console errors, but the full sweep was not done.
- **C4.** Rollback drill executed, or the rollback procedure confirmed executable against a verified backup (G12 AMBER). Rollback is documented per migration, never executed against production.
- **C5.** Staging migration test run (G2 AMBER). Run migrations 001, 002, 003, 006 against the staging Supabase project and verify the result. The ledger is now populated in production, but the staging test itself is still owed.
- **Google sign-in end to end.** Button present, provider ENABLED in Supabase production 08:41, real Client ID from the Google Cloud Console OAuth client "Sortes" in the RAG-ChatBot project rag-chatbot-498522, production callback URI added. Google sign-in itself was not attempted; Google Cloud notes settings may take 5 minutes to a few hours to take effect.
- **Password sign-in untested on production.** The test-account password is unknown. Auth stays at 9, not 10, until Google and password sign-in are both proven on production.
- **Docs fix.** STAGING.md and the db.ts header say transaction mode 6543 is required, but the app uses session mode 5432. Update STAGING.md lines 91 to 92 and 201 to 203 and the db.ts header to state session mode, why, and the pool-size consideration for the Nano tier. Wait for a clean soak first.
- **Pricing server-rendering (roast R3).** /oracles server HTML (33.6 KB) contains no prices and no pack names. Pricing is still client-rendered. Prices in code are correct and checkout works, so it is not a blocker. If server-rendering is wanted, schedule it as a follow-up.
- **Staging concurrency soak.** Run a concurrency test against the staging session-mode pooler to check pool exhaustion on the Nano tier (pool size 15). Proposed in the Claude Code production-switch review, not yet run.
- **Phase D measurement.** 6 generations, first-attempt 3/6 or better, median under 60 s. Unrun.
- **170 s vs 120 s watch item.** Measure real generation latency. Any success over 115 s reopens the cap before it is treated as settled.
- **Real production payment still unproven.** The live checkout page loads, but no real production payment has been made. Payments stays at 9, not 10. A 10 needs a real production payment credited correctly.
- **Postgres 17.11 upgrade offered, not applied, needs approval.** Tiered pricing blocked. Paid AI fallback and a one-time $10 OpenRouter credit purchase both unapproved and unpurchased. Playwright overflow CI gate (P1-4) open. Pack price colour (P1-1, gold vs primary text) still the owner's decision. Delete-by-code for passwordless accounts (P1-12) still the owner's decision. The daily 03:00 VM cron still fails on the Direct network protocols permission, so GitHub Actions is the backup path.
- **Accepted risks not closed by Phase I:** fabricated-report save via POST /api/reports; session-expiry guest degradation (1 Oracle per expiry); guest double-free Quick Insight (1 Oracle per user); history id collision; refund branch without getOrder symmetry; the Ashtakavarga grid verified against a transcribed published grid, not fetched against an external Astro Clock AI source; two cross-city four-hour assertions near-trivia; pending-refund marker rows have null user_id and are not removed by deleteUser; the plans file lives in goal hidden_files, not the repo, so it is not versioned with release candidate commits.
- **Backup gaps.** The Drive upload, the weekly restore test, and the digest watchdog check are design steps, not yet evidenced as run. The auth.users count in the dump (design Q4) is not answered by the

verification log, which counts only the 7 app tables.
- **Other owed live proofs.** Live RLS proof from the anon key (rows before, zero rows after, app still working); AUTH_SECRET session-invalidation live confirmation; live AI generation against the production OpenRouter configuration.

17. Lessons extracted (what the playbook is built from)

These are the lessons the companion playbook formalises. Each one is grounded in a specific event above.

17.1 What worked exceptionally well

1. **Independent review at every stage.** The readiness review, the Phase B adversarial review, and the revised readiness review each caught false claims and real defects the builders missed. The review that found the limiter claim false and the "160/160 tests" claim misleading is the single highest-value act in the whole journey.
2. **The deploy-order rule, once stated.** Migrations before merge and deploy, with a pg_dump before and after. It was missing from every earlier plan and was the rule that would have prevented Bug 1 had the procedure been followed.
3. **Backup first, then everything else.** G1 going GREEN before the merge is what made the production day survivable. The backup was restore-verified, not just created.
4. **Log-driven diagnosis for the hang.** Four rounds, each with a snapshot, a measurement, and a named mechanism. The per-instance id and structured logging in b19ec8a are the only reason the 00:33 and 00:35 stalls could be analysed at all.
5. **The one-retry rule.** At most one retry per step, then diagnose from logs, code, the internet, GitHub, and docs. It stopped the retry loops that had been wasting runs.
6. **Using Claude as a second brain with verification.** Claude's checkout 401 diagnosis (code correct, ranked causes, how to confirm) was precise and grounded, and it was then verified independently against the dashboards before acting on it.
7. **The secret-handling pattern.** A browser task creates a new key in the provider dashboard and pastes it directly into the target field; the agent never sees the value. Used successfully for the Supabase SMTP key and the Lemon Squeezy live key.
8. **Per-environment separation.** Separate env entries per environment, separate test and live keys, variants, and webhooks, and a written do-not-add list. It prevented cross-environment contamination even when the work was rushed.
9. **The tracker and decision log as the single source of truth.** Every significant decision with its reasoning, trade-off, and what would change it. Duplicate tracker rows were removed because duplicate rows make the tracker ambiguous.
10. **Fail-closed design.** The production verify-only migration guard, the 402 before AI generation, the atomic free-use claims, the spend guard, and the pwdVer session version all fail closed. Each one was added because a fail-open path had been found.

17.2 What failed and why

1. **Claims without verification.** The limiter claim, the "160/160 tests" claim, the charts 44px claim, the parity audit's "live-mode key" claim, and the "sign-in verified" claim from a setting. Every one was false

or misleading, and every one was caught by an independent check. The failure mode is always the same: asserting from the new code instead of measuring the live system.

2. **The SQL Editor route for production migrations.** It applied the SQL correctly and silently skipped the ledger, which bricked every DB-backed operation. The procedure existed (migrate CLI) and was not followed, and the deploy-order gate was not executed as a gate.
3. **The first live key.** A key was created and set, but the saved value was damaged or wrong, and nothing verified the value before the smoke test. The dashboards could not show the masked value, so the failure was only visible in the Vercel logs as a 401.
4. **The hang.** Four rounds of fixes, each correct in itself, each failing to fix the hang, because the root cause was never proven. The session-mode switch fixed the symptom on staging with a small sample and confounders. The honest limits were recorded, which is the right response to an unproven root cause, but the root cause is still unknown.
5. **AI reliability.** 0/3 first-attempt success, then repeated chain changes without a measurement plan run. The Phase D measurement plan existed and was never run, so chain changes were made on anecdote.
6. **Visual and mobile verification deferred at every stage.** The transformation, Phase 6, Phase 7, Phase 8A, and Phase I all left the real-device 390px test owed. It is still RED at the end.
7. **Docs drift.** STAGING.md, ENVIRONMENT.md, BACKUP-RECOVERY.md, PRODUCTION-CHANGE-PLAN.md, staging-preview-env.md, and the db.ts header all contradict the live state in at least one place. Docs were written at a point in time and never re-verified after the state changed.
8. **The owner resetting the production password mid-operation.** The live site went DOWN because the password changed before the redeploy. The instruction not to reset arrived after the reset had happened. Coordination on a live credential change needs a lockstep sequence, not a message.
9. **The VM cron as primary backup.** It failed on the first run (age keypair missing, then the direct DB permission). The fallback became the primary. The design's primary was never the working path.
10. **A1 and A2 were needed because the parity was assumed, not checked.** The production SMTP was not configured and the preview wildcard redirect was missing. Both were found by an audit, not by a test.

17.3 What the owner repeatedly had to remind the agent to do

- Never inflate scores. A 100 that rests on a retry hiding a 0/3 first-attempt rate is a false completion claim.
- Use the internet or official trusted guides first when stuck. Never guess from memory.
- Do not try again and again. At most one retry, then diagnose.
- Verify before claiming anything. Never claim a schedule, submission, upload, or live listing that is not real.
- Tracker before action; decision log for every significant decision, with reasoning and what would change it.
- Use Claude always, as a second brain or first brain, and argue with him; never take what Claude says as right, and Claude must argue back.
- The brainstorm gate before anything new: can we do it, is it worth it, is it profitable or does it move revenue.
- Browser first, always, before an API or connector route.
- SkillSpector before installing or first-using any skill.
- ub-mode on every code change.
- Never use em dashes.

- The production password is NOT to be hunted for. It exists only masked in Vercel. Request it from the owner via Secure Vault.

17.4 What should have been automatic

- A CI merge gate that verifies the migration ledger before a production deploy, instead of a manual gate that was skipped.
- A startup assertion that the database connection role is the owner role (RLS safety depends on it entirely).
- A post-deploy smoke test that runs automatically and blocks the release on failure, instead of a manual browser task hours later.
- A secret-value verification step (length check, format check) at the moment a key is pasted, instead of discovering a bad value from a 401 in production logs.
- A scheduled workflow health check that notices the VM cron failing on its first run, instead of discovering it the next morning.
- A docs-freshness check that flags STAGING.md, ENVIRONMENT.md, and the db.ts header when the live state changes.
- An alert for webhook failures and for a Resend outage, instead of invisibility until a customer complains.
- A test that pins the charts-check assertion to the current copy, so a copy change cannot silently break the gate (it did break it, and the gate was red for weeks).

17.5 What verification was missing or performed too late

- Magic-link callback end to end was never exercised at Phase A, Phase B, or in any listed plan file. The Phase 8A, Phase G, and Phase D E2E plans are plans only, explicitly not run.
- The production ledger was never verified before the merge. The deploy-order gate named the check and it was not executed.
- The Lemon Squeezy live key was never verified before the smoke test. The first proof it was invalid came from production logs.
- The live RLS proof from the anon key was never run.
- The staging concurrency soak for session mode was never run.
- The Phase D AI measurement was never run.
- The rollback drill was never executed.
- The real-device 390px test was never done.
- The full console-error sweep was never done.
- A real production payment was never made (by design, unapproved), so Payments stays at 9.

Appendix: key references

A.1 Files

- Tracker: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Transformation-Tracker-2026-11-05.md
- Decision log: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Mission-Decision-Log-2026-11-07.md

- Gate pack: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Phase-H-Gate-Evidence-Pack-2026-11-07.md
- Phase 8A report: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Phase-8A-Report-2026-11-07.md
- Revised readiness: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Revised-Readiness-2026-11-08.md
- Phase I acceptance: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Phase-I-Acceptance-2026-11-08.md
- Roast: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Roast-2026-11-05.md
- Reach plan: ~/workspace/goals/sortes-tarot-reading-app/files/Sortes-Reach-Plan-2026-11-07.md
- Production bugs diagnosis: ~/workspace/goals/sortes-tarot-reading-app/hidden_files/production-bugs-diagnosis-2026-11-08.md
- Parity audit: ~/workspace/goals/sortes-tarot-reading-app/hidden_files/preview-production-parity-audit-2026-11-08.md
- Session-mode recommendation: ~/workspace/goals/sortes-tarot-reading-app/hidden_files/production-session-mode-recommendation.md
- Claude checkout diagnosis: ~/workspace/goals/sortes-tarot-reading-app/hidden_files/claude-checkout-401-diagnosis-2026-11-08.md
- Backup runs log: ~/workspace/goals/sortes-tarot-reading-app/hidden_files/backup-runs.log
- Repo docs: ~/workspace/sortes/docs/ENVIRONMENT.md, docs/STAGING.md, docs/BACKUP-RECOVERY.md, docs/PRODUCTION-CHANGE-PLAN.md

A.2 Key commits

- 5a044fd Phase 1: competitor research, visual style bible, Next.js 16 scaffold (first commit)
- fa02ea8 roast baseline (tag pre-transformation-fa02ea8)
- 859bdb6 transformation delivery
- 6381be2 Phase 6 HEAD
- ad68ce7 Phase 7 HEAD (pushed to origin)
- 1c0bd9f Phase 8A A1 magic-link copy
- e6a5fb5 Phase 8A A2 AI retry
- 32b506f checkout attribution by signed-in user id
- 37b6c0f magic-link redirect allow-list gap
- c7f2ba4 statement_timeout 10 s
- dafc067 client-side 12 s deadline
- d1c698a cancel DB queries on timeout
- 1c690fa postgres.js 4.0.0 to 4.1.0, cancel_timeout
- b19ec8a cancellable migration-ledger check
- edc7b25 chart maxTokens 1200 to 2000
- 272e9cb Phase D AI chain reorder
- 66f1be6 backup workflow install
- d54a639 temporary push trigger for first backup run
- a9f7d08 remove temporary push trigger
- c84f92d merge origin/main into sortes-transformation-2026-11-05 (Phase H release)
- 1c19e68 callback flowId fix plus Google button

A.3 Key deployments and runs

- Preview (Phase 7): sortes-muse-5ig64jpm6-velus-projects-27f81f38.vercel.app, commit ad68ce7
- Preview (8A): sortes-muse-eyh9suhmh-velus-projects-27f81f38.vercel.app, commit e6a5fb5, Ready 2026-11-07 02:53:43 Manila
- Staging session-mode test: deployment DdGn35m8F, Ready 2026-11-08 01:22
- Production (merge): 35 s build, Nov 8 2026 7:41:06 AM GMT+8, commit c84f92d
- Production (callback fix): deployment 8o8Axqrtk, Ready 08:48, commit 1c19e68
- Production (fresh key): deployment BLdAJQ3ja, Ready 09:13, commit 1c19e68
- Backup run 42423673087, 45 s, SUCCESS, artifact 321,479 bytes, 2026-11-08 07:07
- Test purchase order lemonsqueezy:9973511 (staging, balance 10 to 15)
- Test purchase order lemonsqueezy:9965127 (Preview Phase 7, balance 0 to 5 to 4)
- Test purchase order lemonsqueezy:9967615 (Preview 8A, $3.99, credited to the wrong account)

A.4 Production facts at Phase I (2026-11-08 09:18)

- Live site: https://sortes.resonantatlas.com, deployment BLdAJQ3ja, commit 1c19e68
- Supabase production: "VELU1231's Project", ref adgputwbdtdmgkiswtnz, PG 17.6.1.166, FREE plan, NANO compute, about 27 MB, pool size 15, max connections 200
- Production data: 1 user (velu2k03@gmail.com, 128 credits), 8 transactions, 1 reading
- Supabase staging: "Sortes Staging", ref rztkdkespxliddkdafok, ap-northeast-1, FREE, Nano
- Lemon Squeezy: store 244487 (Resonant Atlas, pay.resonantatlas.com); live variants 2331899/2331901/2331903; test variants 2344113/2344118/2344120; live webhook 148741 (order_created plus order_refunded); test webhook 149521
- Resend: domains resonantatlas.com and sortes.resonantatlas.com verified; sender noreply@sortes.resonantatlas.com; staging limit 100/hour
- Vercel: project sortes-muse, team velus-projects-27f81f38; Production 26 env vars, Preview 0